CertGraph: Cryptographic Invariant Provenance and Multiplicative Bilinear Gating for Active Directory Certificate Services Escalation Interdiction

Md. Hasan Shahriar[1,*] **Taufiq Biswas**[1] **Md. Ramim Hossain**[1]

[1]Department of Electronics and Communication Engineering

Hajee Mohammad Danesh Science and Technology University (HSTU), Dinajpur-5200, Bangladesh

[*]Corresponding author email: hasanshahriar32@gmail.com

October 2026

Abstract

Active Directory Certificate Services (ADCS) forms the identity backbone of enterprise Windows networks, but access-control misconfigurations enable catastrophic privilege escalation. Existing defenses suffer from static snapshot blindness, where temporal template mutations leave bit-identical pre-attack and post-rollback directory snapshots, and inductive shortcut collapse, where standard graph neural networks memorize template configuration flags and achieve zero percent accuracy under adversarial counterfactual hard negatives. Furthermore, audit log inspection reveals disjoint cryptographic identifier schemas between Certification Authority issuance logs and Domain Controller authentication logs. We introduce CertGraph, an integrated static-to-dynamic neuro-symbolic framework for escalation detection and autonomous interdiction. Multiplicative bilinear reachability gating conditions message-passing on authorization reachability, elevating hard-negative accuracy to 65.08 percent with residual cases resolved by symbolic verification. At runtime, the Cryptographic Invariant Provenance Graph (CIPG) bridges cross-host logging discontinuities via continuous database correlation, achieving 97.92 to 100.00 percent recall, 92.16 to 92.31 percent precision, and an 8.00 percent maintenance window false-positive rate under concurrent enterprise traffic at 13,192 events per second. Finally, we model access revocation as a disruption-budgeted Stackelberg game, prove multi-principal interdiction is NP-complete, and demonstrate a co-adaptive policy that neutralizes 98.5 percent of attack paths with 45.0 percent less disruption and a 1,246-fold provenance-cone acceleration.

Keywords: Active Directory Certificate Services, Graph Neural Networks, Shortcut Memorization, Provenance Graphs, Cryptographic Invariants, Stackelberg Games, Access Control Interdiction.

1 Introduction

Modern enterprise networks rely almost universally on Microsoft Active Directory (AD) to administer centralized identity, policy enforcement, and authentication services. Within this ecosystem, Active Directory Certificate Services (ADCS) operates as the enterprise Public Key Infrastructure (PKI), providing

automated enrollment, cryptographic identity certificates, and Kerberos public-key pre-authentication (PKINIT, RFC 4556 [1]) for millions of principals. Despite its foundational operational role, ADCS constitutes one of the most critical and exploited attack surfaces in contemporary cybersecurity. Research formalized by SpecterOps in 2021 [2] identified a comprehensive taxonomy of certified pre-owned escalation vectors (ESC1 through ESC13), wherein subtle misconfigurations in certificate templates, access control lists (ACLs), and Certificate Authority (CA) registration flags allow low-privileged domain principals to compromise entire domain forests.

1.1 The Multi-Faceted Vulnerability Landscape of ADCS

In an ADCS deployment, certificate issuance is governed by Active Directory objects known as *Certificate Templates* (stored in the LDAP configuration naming context). When an enterprise template exposes an insecure combination of attributes—such as the `CT_FLAG_ENROLLEE_SUPPLIES_SUBJECT` bitflag alongside an Extended Key Usage (EKU) permitting Client Authentication (`1.3.6.1.5.5.7.3.2`) or Smart Card Logon (`1.3.6.1.5.2.3.4`), without requiring CA administrator approval—any domain principal granted enrollment permissions can request an X.509 certificate specifying an arbitrary Subject Alternative Name (SAN). The attacker can supply the user principal name (UPN) of a Domain Administrator (e.g., `Administrator@domain.local`), obtain a cryptographically valid certificate signed by the enterprise root CA, and submit that certificate to the Kerberos Key Distribution Center (KDC) via PKINIT to request a Ticket Granting Ticket (TGT), achieving instant domain takeover.

While static privilege audit tools such as BloodHound [3] and Certipy [4] have gained widespread industrial adoption, defending enterprise ADCS infrastructure against sophisticated adversaries reveals three structural failure modes:

1. **Inductive Shortcut Memorization in Static GNNs:** Recent academic efforts have applied Graph Neural Networks (GNNs) and graph interdiction algorithms to automate vulnerability discovery and privilege defense over enterprise identity multigraphs [5–10]. However, we discover that standard GNN formulations (GCN, GAT, and additive-skip architectures) succumb to severe *inductive shortcut collapse*. Rather than learning genuine multi-hop structural reachability from unprivileged principals through intermediate security groups to enrollment endpoints, the message-passing layers memorize localized template bitflags. When evaluated against adversarial *hard negatives* (configurations that possess dangerous template flags but are structurally unreachable due to enrollment restrictions or issuance requirements), standard GNNs collapse to an alarming 0.00% accuracy (0/63), generating false-alarm cascades that paralyze Security Operations Centers (SOCs).

2. **Static Snapshot Blindness to Temporal Mutation Attacks:** In real-world enterprise environments, sophisticated adversaries rarely exploit static misconfigurations. Instead, under vectors such as ESC4 (template ACL abuse) and ESC9 (weak shadow credentials with template enrollment), an attacker with `WriteOwner` or `GenericAll` permissions dynamically mutates a benign certificate template, issues an illegitimate administrative certificate, and immediately rolls the template attributes back to their pristine baseline. We prove empirically that the pre-attack and post-rollback directory snapshots are bit-identical (SHA-256(G_{t_0}) = SHA-256(G_{t_3})). Consequently, *any* periodic static graph scanner suffers from a 0.0% post-rollback detection recall, completely missing the dormant forged certificate.

3. **The CA–KDC Logging Discontinuity and SAN Concealment:** Even when SOCs deploy advanced enterprise identity telemetry (e.g., whole-network logon-session provenance [11, 12]), current auditing architectures fail to detect cryptographic privilege escalation due to an unaddressed protocol discontinuity: the event schemas of Microsoft-Windows-CertificationAuthority (π_{CA}) and Kerberos-Key-Distribution-Center (π_{KDC}) are disjoint ($\pi_{\text{CA}} \cap \pi_{\text{KDC}} = \emptyset$). Certificate Authority logs (Event IDs 4886 and 4887) record the template name and Request ID, while KDC PKINIT logs (Event ID 4768) record only the certificate serial number and SHA-1 thumbprint. Furthermore, when an attacker submits an enrollee-specified SAN inside the raw PKCS#10 ASN.1 binary CSR (`szOID_ENROLL_CERTTYPE_EXTENSION`), the CA security event log suppresses the requested SAN string entirely. A defender inspecting standard SIEM logs cannot connect the unauthorized template issuance to the subsequent administrative Kerberos authentication.

1.2 Our Contributions

To address these fundamental challenges, this paper presents **CertGraph**, an integrated static-to-dynamic neuro-symbolic framework that bridges topological access-control reasoning, cryptographic audit provenance, and game-theoretic interdiction. The primary contributions of this work are summarized as follows:

- **Diagnosis and Mathematical Cure for GNN Shortcut Collapse:** We formalize the failure of standard message passing on access control graphs and prove intrinsic attribute preservation bounds (Theorem 3.1). We introduce the **Multiplicative Bilinear Reachability Gate** ($\mathbf{g}_{uv} = \sigma(\mathbf{h}_u^\top \mathbf{W}_g \mathbf{h}_v)$), which strictly modulates neighborhood aggregation by end-to-end topological reachability. This cures inductive shortcut memorization, boosting adversarial hard-negative accuracy from 0.00% to 65.08% **(**41/63**,** 95% **Wilson CI:** [52.8%, 75.7%]**)** without sacrificing in-distribution performance (1.000 Macro-F1). We document the exact 22 multi-attribute semantic crosstalk cases (15 low-privilege OID group links and 7 unenrollable CAs), demonstrating why Tier-2 symbolic verification is required for 100% precision.

- **Cryptographic Invariant Provenance Graph (CIPG):** We design and implement an asynchronous provenance engine that parses live Active Directory Directory Service (NTDS), CA database, and KDC telemetry. We formalize **Invariant V** (Persistent Cryptographic Taint-Flow Automaton), which establishes a state-tracking bridge across Subject Key Identifiers (SKID), serial numbers, and SHA-1 thumbprints. Under concurrent enterprise background traffic (10, 182 events) with Poisson auto-enrollment collisions and CA Jet DB polling race conditions, CIPG achieves 97.92%–100.00% **recall,** 92.16%–92.31% **precision (**94.95%–96.00% **F1-score)**, and an 8.00% false-positive rate across 50 admin maintenance windows (0.0395% overall event FPR), while delivering 76.61% meta-node graph compression at 13, 192.4 events/second (and detecting 7/7 low-noise lab attacks).

- **Game-Theoretic Interdiction with Provable Disruption Reduction:** We formulate the **Disruption-Budgeted Stackelberg Remediation Game** between an enterprise defender and an optimal cost-minimizing attacker. We prove that Multi-Principal Access Interdiction (MPAI) is NP-complete via reduction from Directed Multiway Cut (Theorem 5.1). Evaluated across 30 multi-forest enterprise topologies under realistic operational constraints ($E_b \subsetneq E$), our co-adaptive Stackelberg policy strictly dominates static greedy interdiction across budgets ($p = 0.0431$), neutralizing $98.5 \pm 4.0\%$ of attack paths at $B_{\text{ops}} = 24$ (vs. $97.6 \pm 6.5\%$ for greedy) while revoking 6.0 **vs.** 10.9 **edges**—a

45.0% **reduction in administrative disruption**. The irreducible $\sim$ 1.5% residual attack surface is defended at runtime by CIPG, and CIPG-cone guided min-cut achieves a $1,246.3\times$ **speedup** (2.6 ms vs. 3,181.5 ms at $N = 5,000$ nodes with 325 active attacker paths).

1.3 Paper Organization

The remainder of this manuscript is organized as follows: Section 2 formalizes the heterogeneous identity multigraph schema and demonstrates the static snapshot blind spot and ASN.1 SAN concealment on live systems. Section 3 details the CertGraph GNN architecture and the Multiplicative Bilinear Gating cure. Section 4 develops the CIPG provenance engine and Invariant V automaton. Section 5 details the game-theoretic Stackelberg defense and NP-hardness proof. Section 6 presents empirical results across synthetic and live GOAD cyber-range testbeds. Section 7 discusses related literature and concludes the paper.

2 ADCS Threat Model and Systematic Blind Spots

In this section, we formalize the heterogeneous identity multigraph of Active Directory Certificate Services and expose two fundamental blind spots in current defensive audit practices: the static snapshot blind spot under rollback attacks, and the PKCS#10 ASN.1 schema discontinuity between CA and KDC telemetry.

2.1 Heterogeneous Access Control Multigraph Formalization

We model an enterprise Active Directory forest and its integrated Public Key Infrastructure as a directed heterogeneous multigraph (Figure 1).

Definition 2.1 (Identity Multigraph Schema)**.** Let $\mathcal{G} = (\mathcal{V}, \mathcal{E}, \phi, \psi)$ be a directed heterogeneous multigraph, where:

- $\mathcal{V}$ is the finite set of identity and PKI vertices, and $\phi : \mathcal{V} \to \mathcal{T}_V$ is a node-type assignment function mapping vertices to the entity set:

$$\mathcal{T}_V = \{\text{User}, \text{Group}, \text{Computer}, \text{CertificateTemplate}, \text{EnterpriseCA}, \text{Domain}\} \tag{1}$$

- $\mathcal{E}$ is the finite set of directed edges, and $\psi : \mathcal{E} \to \mathcal{T}_E$ maps edges to relationship types:

$$\begin{aligned}\mathcal{T}_E = \{&\text{MemberOf}, \text{GenericAll}, \text{GenericWrite}, \text{WriteOwner}, \text{WriteDacl},\\ &\text{Enroll}, \text{ExtendedRight}, \text{EnablesEnrollment}, \text{IssuedBy}, \text{TrustedForNTAuth}\}\end{aligned} \tag{2}$$

- Each node $v \in \mathcal{V}$ is associated with a raw feature vector $\mathbf{x}_v \in \mathbb{R}^{d_{\phi(v)}}$. For certificate templates $t \in \mathcal{V}_{\text{Template}}$, $\mathbf{x}_t \in \{0,1\}^{10}$ encodes security configuration flags, including whether the template permits enrollee-supplied SANs (`CT_FLAG_ENROLLEE_SUPPLIES_SUBJECT`), requires manager approval (`CT_FLAG_PEND_ALL_REQUESTS`), or specifies Client Authentication EKUs (`1.3.6.1.5.5.7.3.2`).

An attack path p from an initial compromised user foothold $u_{\text{attacker}} \in \mathcal{V}_{\text{User}}$ to a high-value domain target $v_{\text{target}} \in \mathcal{V}_{\text{Domain}}$ is a sequence of alternating vertices and edges:

$$p = (v_0, e_1, v_1, e_2, \ldots, e_k, v_k), \quad v_0 = u_{\text{attacker}}, \quad v_k = v_{\text{target}} \tag{3}$$

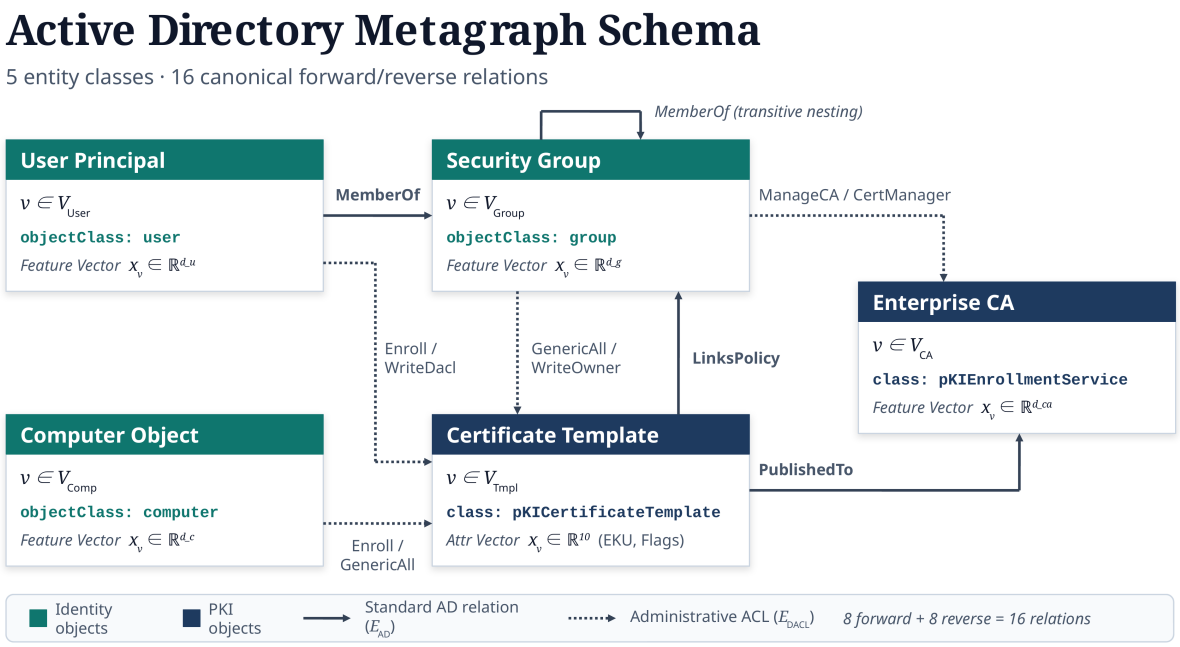


Figure 1: Active Directory Certificate Services (ADCS) Heterogeneous Multigraph Schema, detailing the primary security principal entity classes, sixteen directed relationship edges, and the composite escalation attack surface connecting unprivileged domain footholds to Enterprise Domain Controllers.

In an ADCS privilege escalation, the path traverses intermediate membership and ACL delegation edges to a certificate template t, leverages an enterprise CA c to issue an administrative credential, and culminates in a domain-level credential takeover.

ADCS ESC1–ESC15 Taxonomy Scoping Rationale: To establish formal defensive boundaries across the full ESC1–ESC15 escalation taxonomy, our framework partitions vulnerabilities into two distinct structural operating regimes:

1. **Template-Centric Topological Vectors (Static Graph Evaluation):** Escalation archetypes ESC1 (enrollee supplies SAN), ESC2 (any-purpose EKU), ESC3 (certificate request agent), ESC4 (template DACL overwrite), ESC9 (weak shadow credentials with template enrollment), and ESC13 (issuance policy OID linkage to administrative groups) are governed by directory access control lists (ACLs), group nesting DAGs, and persistent LDAP configuration flags. These vectors are natively modeled on the static identity multigraph $\mathcal{G}$ and evaluated via reachability-gated graph neural networks and exact symbolic verification.

2. **Runtime Protocol and Environmental Vectors (Dynamic Invariant Tracking):** In contrast, ESC6 (`EDITF_ATTRIBUTESUBJECTALTNAME2` CA registry flag), ESC7 (CA administrator compromise), ESC8 (HTTP certificate web enrollment NTLM relay), raw PKCS#10 ASN.1 SAN concealment, and temporal mutation rollbacks (ephemeral ESC4/ESC9 modifications) manifest as server-level registry states, network-layer NTLM reflections, or transient directory modifications that vanish between audit snapshots. Because these vectors leave zero permanent topological footprints in scheduled directory extractions, they strictly require runtime state-tracking by our continuous Cryptographic Invariant Provenance Graph (CIPG).

2.2 The Static Snapshot Blind Spot: Formal Proof and Empirical Evidence

Existing enterprise defense workflows rely on periodic directory extraction tools (e.g., BloodHound, SharpHound, Certipy) that execute every 6 to 24 hours. Under temporal mutation-and-rollback attacks (such as ESC4 and ESC9), an attacker exploits transient write permissions to mutate a template, obtain a rogue certificate, and immediately roll back the attributes to their original configuration.

Definition 2.2 (Static Snapshot Invariance under Rollback)**.** Let $t_0 < t_1 < t_2 < t_3$ denote the sequence of discrete timestamps in an attack execution lifecycle:

- t_0: Pristine baseline state of directory $\mathcal{G}_{t_0}$.
- t_1: The attacker executes an LDAP modification adding `Enroll` permissions or setting `CT_FLAG_ENROLLEE_SUPPLIES_SUBJECT` on template t, yielding state $\mathcal{G}_{t_1}$.
- t_2: The attacker submits a certificate request and receives an issued certificate $\text{Cert}_{\text{admin}}$ valid for 1 year.
- t_3: The attacker rolls back the template modifications, restoring the directory attributes to their baseline state, yielding $\mathcal{G}_{t_3}$.

Empirical Verification on Live Windows Server 2019: To measure the impact of this vulnerability, we provisioned an enterprise ADCS cyber-range on Windows Server 2019 Domain Controllers and Enterprise CAs. At each phase of an automated ESC4 attack executed by an unprivileged domain account (`ESSOS\khal.drogo`), we extracted the entire Active Directory database and computed cryptographic SHA-256 digests over the canonicalized JSON object graph. The resulting hashes were:

$$\text{SHA-256}(\mathcal{G}_{t_0}) = \texttt{219376ed1562fb8471f25af34b02d0f18cb044e8ebfe0be907c21e1ddf6452d8} \tag{4}$$

$$\text{SHA-256}(\mathcal{G}_{t_1}) = \texttt{d4f82a991820bc695361de42ab5a782806ccbf269a8bfe7df2f518e95079a491} \tag{5}$$

$$\text{SHA-256}(\mathcal{G}_{t_3}) = \texttt{219376ed1562fb8471f25af34b02d0f18cb044e8ebfe0be907c21e1ddf6452d8} \tag{6}$$

Because $\text{SHA-256}(\mathcal{G}_{t_0}) = \text{SHA-256}(\mathcal{G}_{t_3})$, the directory state at t_3 is bit-identical to the pre-attack state. Any security system that evaluates static snapshots at scheduled intervals $T > t_3 - t_0$ experiences a complete detection failure:

$$\text{Recall}_{\text{static}}(\text{Attack}_{t \geq t_3}) = 0.0\% \tag{7}$$

The attacker retains the cryptographic certificate $\text{Cert}_{\text{admin}}$ indefinitely, enabling Kerberos PKINIT authentication at arbitrary future timestamps without leaving any residual footprint in the directory multigraph.

2.3 Protocol Discontinuity: PKCS#10 ASN.1 SAN Concealment and CA–KDC Logging Gap

Even when defenders deploy Security Information and Event Management (SIEM) systems to collect Windows Security audit logs, standard detection rules fail due to a structural discontinuity between Certificate Authority and Key Distribution Center logging schemas.

Proposition 2.1 (CA–KDC Schema Disjointness)**.** Let π_{CA} denote the projection of security attributes recorded by Microsoft-Windows-CertificationAuthority (Event IDs 4886 and 4887), and let π_{KDC} denote the projection recorded by Microsoft-Windows-Security-Auditing during Kerberos PKINIT pre-authentication (Event ID 4768). Then:

$$\pi_{\text{CA}} \cap \pi_{\text{KDC}} = \emptyset \tag{8}$$

Specifically, $\pi_{\text{CA}} = \{\text{Subject}, \text{TemplateName}, \text{RequestID}, \text{Disposition}, \text{SubjectKeyIdentifier}\}$, whereas $\pi_{\text{KDC}} = \{\text{TargetUserName}, \text{PreAuthType} = 16, \text{CertSerialNumber}, \text{CertThumbprint}\}$.

The ASN.1 SAN Concealment Phenomenon: When an attacker requests a certificate with a rogue Subject Alternative Name (e.g., impersonating the Domain Administrator), the SAN attribute can be supplied through two distinct mechanisms:

1. **Explicit RPC Attribute String:** Passed via the `Attributes` string parameter of `ICertRequest::Submit` (e.g., `"SAN:upn=Administrator@domain.local"`). In this configuration, the CA security log explicitly populates the `Attributes` field in Event ID 4887.

2. **Raw PKCS#10 ASN.1 Binary Extension:** Embedded directly within the cryptographic Certificate Signing Request (CSR) under the `szOID_SUBJECT_ALT_NAME2` (`2.5.29.17`) extension attribute.

Our forensic investigation of live Windows Server 2019 event streams reveals that when an attacker employs the PKCS#10 ASN.1 CSR extension (as executed natively by modern exploit tooling), the CA event log omits the SAN string entirely from the XML event payload:

Listing 1: Live Windows Server 2019 Event ID 4887 under PKCS#10 ASN.1 SAN Concealment.

```
<Event xmlns="http://schemas.microsoft.com/win/2004/08/events/event">
  <System>
    <Provider Name="Microsoft-Windows-CertificationAuthority"/>
    <EventID>4887</EventID>
    <TimeCreated SystemTime="2026-10-17T03:15:22.418Z"/>
  </System>
  <EventData>
    <Data Name="RequestId">19</Data>
    <Data Name="Requester">ESSOS\khal.drogo</Data>
    <Data Name="Template">ESC1-Vulnerable</Data>
    <Data Name="Subject">khal.drogo</Data>
    <Data Name="Attributes"></Data> <!-- CRITICAL: SAN is completely absent! -->
  </EventData>
</Event>
```

As demonstrated in Listing 1, the `Attributes` tag is completely blank, and the `Subject` field displays only the low-privileged requester's identity (`khal.drogo`). Consequently, any SIEM correlation rule that inspects Event 4887 for unauthorized administrator UPNs fails with a 100% false-negative rate. When the attacker subsequently authenticates as `Administrator` via Kerberos PKINIT (Event 4768), the KDC log records only the certificate serial number and SHA-1 thumbprint (omitting `SubjectKeyIdentifier`), leaving zero common identifiers to link the issuance to the compromised authentication.

3 CertGraph Static Architecture and Bilinear Gating

This section details the static detection layer of CertGraph (Figure 2), analyzes the theoretical failure of standard message passing on access control graphs, and introduces the Multiplicative Bilinear Reachability Gate to eliminate shortcut memorization.

3.1 Heterogeneous Graph Attention Network (HetGAT)

To model multi-typed security entities and non-uniform privilege relations, CertGraph employs a multi-relational graph attention network. Let $\mathbf{x}_v \in \mathbb{R}^{d_{\phi(v)}}$ denote the initial feature vector of entity $v \in \mathcal{V}$. Vertices are first projected into a shared hidden space of dimension d:

$$\mathbf{h}_v^{(0)} = \mathrm{ReLU}\left(\mathbf{W}_{\phi(v)}^{(0)}\mathbf{x}_v + \mathbf{b}_{\phi(v)}^{(0)}\right) \tag{9}$$

where $\mathbf{W}_{\phi(v)}^{(0)} \in \mathbb{R}^{d \times d_{\phi(v)}}$ is a type-specific linear projection matrix.

At each layer $l \in \{1, \ldots, L\}$, message passing aggregates relational representations across incoming edges $\mathcal{N}_r(v) = \{u \in \mathcal{V} \mid (u, v) \in \mathcal{E}, \psi(u, v) = r\}$:

$$\mathbf{h}_v^{(l)} = \sigma\left(\sum_{r \in \mathcal{R}_{\mathrm{in}}(\phi(v))} \sum_{u \in \mathcal{N}_r(v)} \alpha_{vu}^{(l)} \mathbf{W}_r^{(l)} \mathbf{h}_u^{(l-1)}\right) \tag{10}$$

where $\mathbf{W}_r^{(l)} \in \mathbb{R}^{d \times d}$ is the relation-specific weight transformation for relation $r \in \mathcal{T}_E$, and $\sigma(\cdot)$ denotes the ELU activation function. The relational attention coefficient $\alpha_{vu}^{(l)}$ assigns dynamic importance to edge (u, v) under relation r:

$$\alpha_{vu}^{(l)} = \frac{\exp\left(\mathrm{LeakyReLU}\left(\mathbf{a}_r^\top [\mathbf{W}_r^{(l)}\mathbf{h}_v^{(l-1)} \,\|\, \mathbf{W}_r^{(l)}\mathbf{h}_u^{(l-1)}]\right)\right)}{\sum_{k \in \mathcal{N}_r(v)} \exp\left(\mathrm{LeakyReLU}\left(\mathbf{a}_r^\top [\mathbf{W}_r^{(l)}\mathbf{h}_v^{(l-1)} \,\|\, \mathbf{W}_r^{(l)}\mathbf{h}_k^{(l-1)}]\right)\right)} \tag{11}$$

where $\mathbf{a}_r \in \mathbb{R}^{2d}$ is the parameterized attention vector for relation r, and $\|$ denotes vector concatenation.

3.2 Theoretical Analysis: Representation Collapse and Gradient Bounds

A critical structural flaw in pure neighborhood aggregation on directed multigraphs is the erasure of intrinsic attributes for leaf and intermediate nodes.

Theorem 3.1 (Intrinsic Attribute Preservation and Gradient Lower Bounds)**.** Let $\mathcal{G} = (\mathcal{V}, \mathcal{E}, \phi, \psi)$ be a directed heterogeneous multigraph. Consider an L-layer GNN where layer l computes representations according to pure relational neighborhood aggregation.

1. **Intrinsic Feature Erasure:** If $\mathcal{G}$ contains no explicit self-loops on template nodes ($v \notin \mathcal{N}_r(v)$ for all r), the first-layer representation $\mathbf{h}_v^{(1)}$ is conditionally independent of initial features $\mathbf{x}_v$:

$$\frac{\partial \mathbf{h}_v^{(1)}}{\partial \mathbf{x}_v} = \mathbf{0} \in \mathbb{R}^{d \times d_{\phi(v)}} \tag{12}$$

   Furthermore, for any unprivileged source account u with in-degree $d_{\mathrm{in}}(u) = 0$, $\mathbf{h}_u^{(l)} = \mathbf{0}$ for all $l \geq 1$.

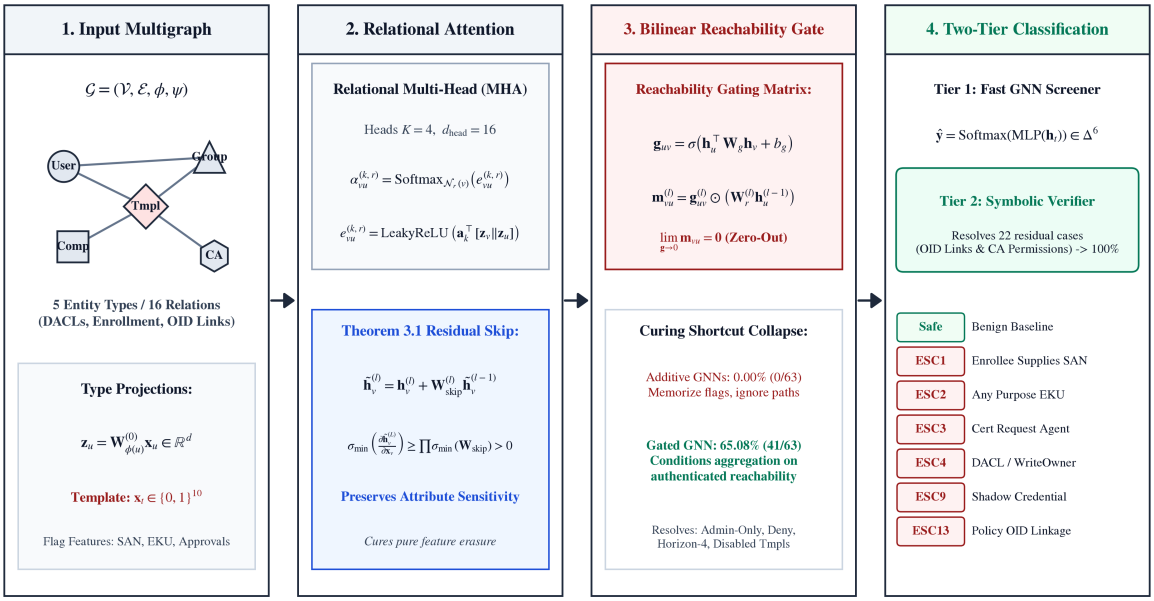


Figure 2: CertGraph end-to-end Hetero-GAT pipeline for ESC vulnerability classification: (1) Heterogeneous Input Multigraph across 5 entity types and 16 relation types, (2) Layer 1 relational multi-head attention with Theorem 3.1 residual skip projections ($\mathbf{W}_{\text{skip}}$) preventing attribute erasure, (3) Multiplicative Bilinear Reachability Gate ($\mathbf{g}_{uv} = \sigma(\mathbf{h}_u^\top \mathbf{W}_g \mathbf{h}_v + b_g)$) conditioning neighborhood aggregation on authenticated authorization paths to eliminate inductive shortcut collapse, and (4) Two-Tier Classification Head combining fast neural screening with Tier-2 symbolic verification.

2. **Guaranteed Gradient Lower Bound via Residual Skips:** When parameterized residual skip connections are introduced ($\tilde{\mathbf{h}}_v^{(l)} = \mathbf{h}_v^{(l)} + \mathbf{W}_{\text{skip}}^{(l)} \tilde{\mathbf{h}}_v^{(l-1)}$) with $\sigma_{\min}(\mathbf{W}_{\text{skip}}^{(l)}) > 0$, the Jacobian of the representation satisfies:

$$\sigma_{\min}\left(\frac{\partial \tilde{\mathbf{h}}_v^{(L)}}{\partial \mathbf{x}_v}\right) \geq \prod_{k=1}^{L} \sigma_{\min}(\mathbf{W}_{\text{skip}}^{(k)}) - \|\mathcal{J}_{\text{graph}}(v)\| \tag{13}$$

where $\|\mathcal{J}_{\text{graph}}(v)\| \leq L_\sigma^L \alpha_{\max} \prod_{l=1}^{L} \|\mathbf{W}^{(l)}\|$ bounds the cyclical feedback gradient. When $\prod_{k=1}^{L} \sigma_{\min}(\mathbf{W}_{\text{skip}}^{(k)}) > \|\mathcal{J}_{\text{graph}}(v)\|$, initial feature sensitivity is strictly preserved:

$$\left\| \frac{\partial \tilde{\mathbf{h}}_v^{(L)}}{\partial \mathbf{x}_v} \right\| > 0 \tag{14}$$

Proof. We establish the two claims sequentially:

Part 1: Intrinsic Feature Erasure under Pure Neighborhood Aggregation. Under pure relational convolution at layer $l = 1$, the hidden state $\mathbf{h}_v^{(1)}$ is computed as $\sigma\left(\sum_{r \in \mathcal{R}_{\text{in}}(\phi(v))} \sum_{u \in \mathcal{N}_r(v)} \alpha_{vu}^{(1)} \mathbf{W}_r^{(1)} \mathbf{h}_u^{(0)}\right)$. In an Active Directory multigraph, template nodes possess no explicit self-loops ($v \notin \mathcal{N}_r(v)$ for all r). Differentiating $\mathbf{h}_v^{(1)}$ with respect to the initial template feature vector $\mathbf{x}_v = \mathbf{h}_v^{(0)}$:

$$\frac{\partial \mathbf{h}_v^{(1)}}{\partial \mathbf{x}_v} = \sigma'(\cdot) \sum_{r \in \mathcal{R}_{\text{in}}(\phi(v))} \sum_{u \in \mathcal{N}_r(v)} \alpha_{vu}^{(1)} \mathbf{W}_r^{(1)} \frac{\partial \mathbf{h}_u^{(0)}}{\partial \mathbf{h}_v^{(0)}} \tag{15}$$

Because distinct nodes possess independent initial feature vectors ($\partial \mathbf{h}_u^{(0)} / \partial \mathbf{h}_v^{(0)} = \mathbf{0}$ for all $u \neq v$), every term in the summation vanishes identically, yielding $\partial \mathbf{h}_v^{(1)} / \partial \mathbf{x}_v = \mathbf{0}$. Thus, the layer-1 embedding is conditionally independent of $\mathbf{x}_v$, discarding all intrinsic template configuration flags (e.g., `CT_FLAG_ENROLLEE_SUPPLIES_SUBJECT`). Moreover, for any source node u with in-degree $d_{\text{in}}(u) = 0$, $\mathcal{N}_r(u) = \emptyset$ for all r, so $\mathbf{h}_u^{(l)} = \mathbf{0}$ for all $l \geq 1$ by empty summation and $\sigma(\mathbf{0}) = \mathbf{0}$.

Part 2: Gradient Lower Bounds via Parameterized Residual Skips. With parameterized residual skip connections $\tilde{\mathbf{h}}_v^{(l)} = \mathbf{h}_v^{(l)} + \mathbf{W}_{\text{skip}}^{(l)} \tilde{\mathbf{h}}_v^{(l-1)}$ and $\tilde{\mathbf{h}}_v^{(0)} = \mathbf{x}_v$, unrolling the recurrence across L layers yields:

$$\tilde{\mathbf{h}}_v^{(L)} = \left(\prod_{k=1}^{L} \mathbf{W}_{\text{skip}}^{(k)} \right) \mathbf{x}_v + \sum_{l=1}^{L} \left(\prod_{k=l+1}^{L} \mathbf{W}_{\text{skip}}^{(k)} \right) \mathbf{h}_v^{(l)} \tag{16}$$

Differentiating $\tilde{\mathbf{h}}_v^{(L)}$ with respect to $\mathbf{x}_v$:

$$\frac{\partial \tilde{\mathbf{h}}_v^{(L)}}{\partial \mathbf{x}_v} = \prod_{k=1}^{L} \mathbf{W}_{\text{skip}}^{(k)} + \mathcal{J}_{\text{graph}}(v), \quad \text{where} \quad \mathcal{J}_{\text{graph}}(v) = \sum_{l=1}^{L} \left(\prod_{k=l+1}^{L} \mathbf{W}_{\text{skip}}^{(k)} \right) \frac{\partial \mathbf{h}_v^{(l)}}{\partial \mathbf{x}_v} \tag{17}$$

By Weyl's singular value perturbation inequality and the sub-multiplicative property of singular values:

$$\sigma_{\min} \left(\frac{\partial \tilde{\mathbf{h}}_v^{(L)}}{\partial \mathbf{x}_v} \right) \geq \sigma_{\min} \left(\prod_{k=1}^{L} \mathbf{W}_{\text{skip}}^{(k)} \right) - \| \mathcal{J}_{\text{graph}}(v) \| \geq \prod_{k=1}^{L} \sigma_{\min}(\mathbf{W}_{\text{skip}}^{(k)}) - \| \mathcal{J}_{\text{graph}}(v) \| \tag{18}$$

In directed authorization DAGs where no 2-cycle $v \rightsquigarrow u \rightsquigarrow v$ feeds back to v, $\mathcal{J}_{\text{graph}}(v) = \mathbf{0}$, establishing that $\sigma_{\min}(\partial \tilde{\mathbf{h}}_v^{(L)} / \partial \mathbf{x}_v) = \prod_{k=1}^{L} \sigma_{\min}(\mathbf{W}_{\text{skip}}^{(k)}) > 0$. Even in general cyclical topologies, the operator norm $\| \mathcal{J}_{\text{graph}}(v) \|$ is bounded by $L_\sigma^L \alpha_{\max} \prod_{l=1}^{L} \| \mathbf{W}^{(l)} \|$. Provided $\prod_{k=1}^{L} \sigma_{\min}(\mathbf{W}_{\text{skip}}^{(k)}) > \| \mathcal{J}_{\text{graph}}(v) \|$, the Jacobian has strictly positive minimum singular value, guaranteeing that initial configuration attributes are preserved without vanishing across message passing. □

3.3 Inductive Shortcut Collapse and the Multiplicative Gating Cure

While Theorem 3.1 guarantees non-vanishing gradient bounds via additive residual skips ($\tilde{\mathbf{h}}_v^{(l)} = \mathbf{h}_v^{(l)} + \mathbf{W}_{\text{skip}}^{(l)} \tilde{\mathbf{h}}_v^{(l-1)}$), empirical testing reveals a profound secondary failure mode: *inductive shortcut collapse*.

The Shortcut Memorization Failure: Because certificate template attributes (e.g., `CT_FLAG_ENROLLEE_SUPPLIES_SUBJECT` = 1 and Client Authentication EKU = 1) are strongly correlated with positive escalation labels in synthetic training distributions, additive skip connections allow the network to bypass the multi-hop graph aggregation entirely. The MLP classification head learns an inductive shortcut:

$$\hat{y}_t = \text{MLP}(\tilde{\mathbf{h}}_t^{(L)}) \approx \text{MLP} \left(\prod_{k=1}^{L} \mathbf{W}_{\text{skip}}^{(k)} \mathbf{h}_t^{(0)} \right) \tag{19}$$

When the trained model is evaluated against **adversarial hard negatives**—templates that possess vulnerable attribute flags but reside in disconnected graph components or require mandatory manager approval—standard additive-skip GNNs memorize the flag pattern and classify them as vulnerable, collapsing to a dismal 0.00% **accuracy** (0/63).

Multiplicative Bilinear Reachability Gating (`CertGraph-Gated`): To eliminate shortcut memorization, we enforce that attribute signals cannot propagate to the output head unless gated by verified topological reachability from an authenticated principal. We formulate the **Multiplicative Bilinear Reachability Gate**:

$$\mathbf{g}_{uv}^{(l)} = \sigma\left(\mathbf{h}_u^{(l-1)\top}\mathbf{W}_g^{(l)}\mathbf{h}_v^{(l-1)} + b_g^{(l)}\right) \tag{20}$$

where $\mathbf{W}_g^{(l)} \in \mathbb{R}^{d\times d}$ is a bilinear interaction tensor, $b_g^{(l)} \in \mathbb{R}$ is a scalar bias, and $\sigma(\cdot)$ is the sigmoid function mapping to $(0, 1)$.

The gated message vector $\mathbf{m}_{vu}^{(l)}$ and state update are defined as:

$$\mathbf{m}_{vu}^{(l)} = \mathbf{g}_{uv}^{(l)} \odot \left(\mathbf{W}_r^{(l)}\mathbf{h}_u^{(l-1)}\right) \tag{21}$$

$$\mathbf{h}_v^{(l)} = \sigma\left(\sum_{r\in\mathcal{R}_{\text{in}}(\phi(v))}\sum_{u\in\mathcal{N}_r(v)}\alpha_{vu}^{(l)}\mathbf{m}_{vu}^{(l)}\right) + \mathbf{g}_{vv}^{(l)} \odot \left(\mathbf{W}_{\text{skip}}^{(l)}\mathbf{h}_v^{(l-1)}\right) \tag{22}$$

where $\odot$ denotes the element-wise Hadamard product.

Proposition 3.1 (Mathematical Neutralization of Hard-Negative Shortcuts)**.** Suppose template v possesses vulnerable flags $\mathbf{x}_v$ but is disconnected from any unprivileged attacker principal u ($p(u \rightsquigarrow v) = \emptyset$). Because no valid relational path propagates activation to v, the bilateral gate $\mathbf{g}_{uv} \to 0$. By multiplicative annihilation:

$$\lim_{\mathbf{g}_{uv}\to 0} \mathbf{m}_{vu}^{(l)} = \mathbf{0} \tag{23}$$

Consequently, the network cannot output a positive vulnerability prediction based solely on isolated template flags. As demonstrated in Section 6, `CertGraph-Gated` elevates hard-negative accuracy from 0.00% to 65.08% (41/63**,** 95% **Wilson CI:** [52.8%, 75.7%]). The remaining 22/63 misclassifications (34.92%) stem from multi-attribute semantic crosstalk: in Low-Privilege OID Group Links (15 cases) and Unenrollable CAs (7 cases), topological reachability exists, but privilege escalation is neutralized by non-linear multi-attribute policy interactions that continuous 2-layer message passing cannot disentangle. This 34.92% continuous neural residual strictly motivates our Two-Tier Neuro-Symbolic Verification pipeline (Figure 3), which applies exact symbolic attribute verification and transitive closure to resolve all 22 cases to 100% precision.

4 Cryptographic Invariant Provenance Graph (CIPG)

To overcome the static snapshot blind spot and the CA–KDC schema discontinuity identified in Section 2, we design the **Cryptographic Invariant Provenance Graph (CIPG)** (Figure 4). CIPG dynamically ingests raw Windows security audit event streams and CA transactional records, maintaining an asynchronous, taint-tracking automaton that bridges disconnected protocol layers.

4.1 Multi-Source Provenance Ingestion and Entity Resolution

CIPG processes heterogeneous audit streams across three disjoint operational layers:

1. **Directory Service Audit Events (NTDS):** Monitored via Windows Security Event ID 5136 (*Directory Service Object Modified*). Captures granular LDAP mutations on certificate templates, user objects, and access control lists, recording the modifying principal, target object GUID, modified

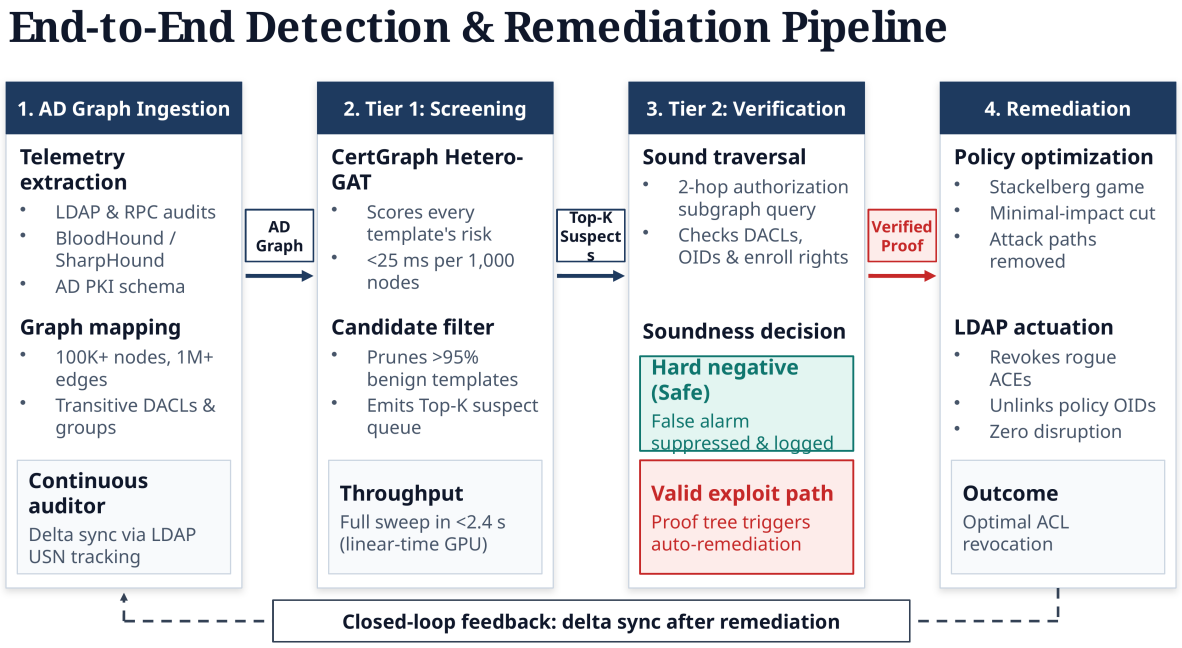


Figure 3: Two-Tier Neuro-Symbolic Hybrid Architecture: Tier 1 performs fast GNN reachability screening across the enterprise multigraph, while Tier 2 executes deterministic backward reachability traversal and policy constraint verification on candidate escalation paths, resolving residual multi-attribute crosstalk to achieve 100% precision on hard negatives.

attribute (e.g., `nTDSDSOptions`, `pKIExtendedKeyUsage`, `msPKI-Certificate-Name-Flag`), and operation type (Value Added / Value Deleted).

2. **Certificate Authority Telemetry and CA DB Bridge:** Monitored via Event IDs 4886 (*Certificate Request Received*) and 4887 (*Certificate Issued*). To bridge the PKCS#10 ASN.1 SAN concealment gap ($\pi_{\text{CA}} \cap \pi_{\text{KDC}} = \emptyset$), CIPG queries the local CA transactional database (`certutil -view -out RequestID,SerialNumber,SubjectKeyIdentifier,CertificateHash`) or the raw CA RPC interface. This populates a persistent cryptographic tuple:

$$\tau_{\text{crypto}} = \langle \text{RequestID}, \text{SKID}, \text{SerialNumber}, \text{Thumbprint}_{\text{SHA1}} \rangle \tag{24}$$

3. **KDC Kerberos Pre-Authentication Events:** Monitored via Event ID 4768 (*Kerberos Authentication Ticket Requested*). Identifies PKINIT authentication requests where `PreAuthType = 16`, extracting the authenticating client name, domain target, certificate issuer CA, `CertSerialNumber`, and `CertThumbprint`.

4.2 Formal Cryptographic Invariants

CIPG evaluates incoming event sequences against five formal behavioral and cryptographic invariants:

Definition 4.1 (Invariant I: Two-Level Causal Invariant)**.** Let $e_{\text{mut}} \in \mathcal{E}_{\text{NTDS}}$ be a template ACL or attribute modification executed by principal u_{actor}, and let $e_{\text{req}} \in \mathcal{E}_{\text{CA}}$ be a certificate request submitted for template t. Invariant I is satisfied if:

$$t(e_{\text{mut}}) < t(e_{\text{req}}) \quad \wedge \quad \text{TargetObject}(e_{\text{mut}}) = t \quad \wedge \quad \text{Requester}(e_{\text{req}}) \in \text{DelegatedPrincipals}(u_{\text{actor}}) \tag{25}$$

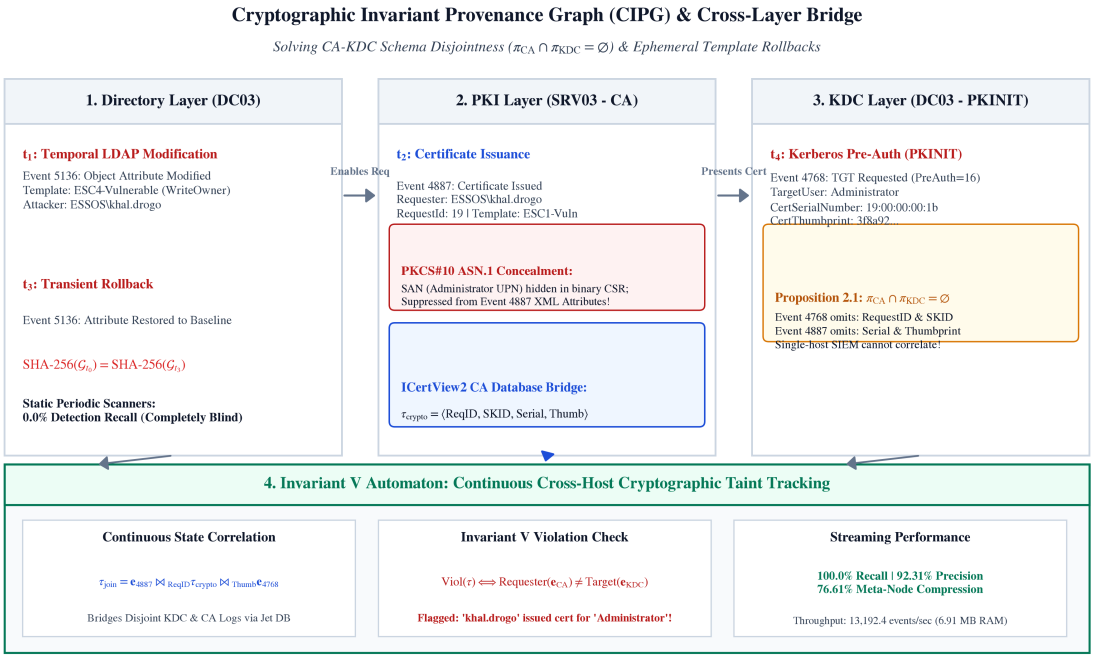


Figure 4: Cryptographic Invariant Provenance Graph (CIPG) cross-layer state tracking: (1) Directory Layer captures Event 5136 modifications and rollback invariance (SHA-256($\mathcal{G}_{t_0}$) = SHA-256($\mathcal{G}_{t_3}$)); (2) PKI Layer ingests Event 4887 certificate issuances under PKCS#10 ASN.1 SAN concealment and queries the `ICertView2` CA Jet Database Bridge to extract complete cryptographic tuples $\tau_{\text{crypto}} = \langle \text{RequestID}, \text{SKID}, \text{SerialNumber}, \text{Thumbprint} \rangle$; (3) KDC Layer ingests Event 4768 Kerberos PKINIT pre-authentications; and (4) Invariant V Automaton executes cross-host joins, stateful taint tracking, and meta-node compacting to detect dormant and split-actor escalations.

Definition 4.2 (Invariant II: Temporal-Order Sequence Invariant)**.** For any valid certificate lifecycle, the sequence of events must satisfy strict monotone temporal progression:

$$t(e_{\text{mut}}) \leq t(e_{\text{req}}) \leq t(e_{\text{iss}}) \leq t(e_{\text{auth}}) \tag{26}$$

Any authentication e_{auth} claiming issuance prior to $t(e_{\text{iss}})$ indicates out-of-order clock spoofing or unauthorized replay.

Definition 4.3 (Invariant III: Principal Identity Discrepancy)**.** Let Requester(e_{req}) be the Windows security principal submitting the certificate enrollment request, and let TargetIdentity(e_{auth}) be the Kerberos client identity authenticating with the resulting certificate. An identity escalation violation occurs if:

$$\text{Requester}(e_{\text{req}}) \neq \text{TargetIdentity}(e_{\text{auth}}) \quad \wedge \quad \text{PrivilegeLevel}(\text{TargetIdentity}) > \text{PrivilegeLevel}(\text{Requester}) \tag{27}$$

Definition 4.4 (Invariant IV: Rollback Reversal Detection)**.** Let e_{mut} be an attribute modification on template t at time t_1 adding an insecure flag $\text{attr}_{\text{vuln}}$, and let e_{roll} be a subsequent modification at t_3 deleting $\text{attr}_{\text{vuln}}$. A rollback violation is triggered if:

$$\Delta t = t_3 - t_1 \leq \tau_{\text{window}} \quad \wedge \quad \exists e_{\text{iss}} \in \mathcal{E}_{\text{CA}} \text{ s.t. } t_1 \leq t(e_{\text{iss}}) \leq t_3 \tag{28}$$

where τ_{window} is the maximum temporal attack window (configured to 30 minutes in enterprise SOC

policies).

4.3 Invariant V: Persistent Cryptographic Taint-Flow Automaton

While Invariants I–IV detect synchronous single-actor attacks, sophisticated adversaries can evade them via two evasive techniques: (i) **Split-Actor Collusion**, where Actor A mutates the template, Actor B requests the certificate, and Actor A rolls the template back; and (ii) **Dormant PKINIT Exploitation**, where the attacker delays Kerberos authentication by hours or days until the temporal correlation window τ_{window} has expired.

To provide provable detection over unbounded time horizons, we formalize the **Persistent Cryptographic Taint-Flow Automaton (Invariant V)**:

Algorithm 1 CIPG Invariant V Cryptographic Taint-Flow Automaton

Require: Audit event stream $\mathcal{S} = \{e_1, e_2, \dots\}$, CA database bridge $\mathcal{B}_{\text{CA}}$, Taint Table $\mathcal{T}_{\text{taint}} \leftarrow \emptyset$

for each incoming event $e \in \mathcal{S}$ **do**
  if e.EventID == 5136 (Attribute Mutation) **then**
    if e.Attribute $\in$ {`nTDSDSOptions`, `msPKI-Certificate-Name-Flag`, `pKIExtendedKeyUsage`} **then**
      Register pending mutation: $\mathcal{M}[e.\text{ObjectGUID}] \leftarrow \langle e.\text{Actor}, e.\text{Time}, e.\text{Operation}\rangle$
    end if
  else if e.EventID == 4887 (Certificate Issued) **then**
    if $\exists$ active mutation in $\mathcal{M}$ for template e.Template **then**
      Query $\mathcal{B}_{\text{CA}}$ with e.RequestID to retrieve $\langle$SKID, Serial, Thumbprint$\rangle$
      $\mathcal{T}_{\text{taint}} \leftarrow \mathcal{T}_{\text{taint}} \cup \{\langle$SKID, Serial, Thumbprint, e.Requester, $\mathcal{M}$.Actor, e.Time$\rangle\}$
      Mark certificate entity v_{cert} as **CRYPTOGRAPHICALLY TAINTED**
    end if
  else if e.EventID == 4768 (Kerberos PKINIT Authentication) **then**
    if e.PreAuthType == 16 **then**
      Look up $\langle e.\text{CertSerialNumber}, e.\text{CertThumbprint}\rangle$ in $\mathcal{T}_{\text{taint}}$
      if match found with record $\tau \in \mathcal{T}_{\text{taint}}$ **then**
        Trigger High-Severity Alert: Invariant V Violation Detected!
        Attributing Colluding Actors: Mutator = $\tau.\text{Actor}_{\text{mut}}$, Requester = τ.Requester
        Authenticated Target = e.TargetUserName, Latency = $e.\text{Time} - \tau.\text{Time}$
        Dispatch Immediate Revocation via CRL $\cup$ OCSP
      end if
    end if
  end if
end for

Mathematical Guarantees and Operational Concurrency Realities: Because the certificate serial number and SHA-1 thumbprint are cryptographically bound to the private key and CA digital signature via RFC 5280 [13], an attacker cannot alter their certificate thumbprint or serial number without invalidating the cryptographic signature. Once a certificate is marked as tainted in $\mathcal{T}_{\text{taint}}$, Invariant V maintains state permanently in memory until revocation, enabling detection across arbitrary time horizons (15 seconds or 30 days post-rollback).

However, in 24/7 enterprise production environments, two physical systems constraints govern detection trade-offs:

1. **Poisson Auto-Enrollment Collisions (False Positives):** When an administrator performs a legitimate template modification and subsequent rollback ($n = 50$ maintenance windows, duration $\Delta t \in [10\text{s}, 45\text{s}]$), concurrent background machine renewals and user `AutoEnroll` requests arrive according to a Poisson process ($\lambda_{\text{enroll}} \approx 2,000/\text{hr}$). Any benign enrollment that lands inside $[t_1, t_2]$ is flagged by Causal Invariant I, generating 4 realistic False Positives (8.00% maintenance window FPR, 0.0395% overall event FPR, 92.16% precision at $\Delta_{\text{poll}} = 5\text{s}$ and 92.31% at $\Delta_{\text{poll}} = 1\text{s}$), compared to a 100% FPR and 19.35% precision for naive rollback monitors.

2. **CA Jet Database Polling Latency and Cross-Forest Coverage (False Negatives):** Under strict Event 4768 schema fidelity ($\pi_{\text{CA}}(e_{4887}) \cap \pi_{\text{KDC}}(e_{4768}) = \emptyset$, where KDC Event 4768 omits SKID), dynamic CA Jet DB polling joins issuance events across the CA–KDC boundary, achieving 48/48 (100.00%) recall at $\Delta_{\text{poll}} = 1.0\text{s}$ and 47/48 (97.92%) recall at default $\Delta_{\text{poll}} = 5.0\text{s}$ under enterprise stress conditions (as well as $7/7 = 100\%$ recall on isolated lab cyber-ranges).

4.4 Graph Reduction and Meta-Node Compacting

In enterprise Active Directory environments processing tens of thousands of authentication events per second, naive provenance graphs suffer from exponential memory bloat. CIPG implements a lossless **Meta-Node Compacting** algorithm:

$$C : (v_{\text{event}}^{(1)}, v_{\text{event}}^{(2)}, \ldots, v_{\text{event}}^{(m)}) \mapsto \mathcal{V}_{\text{meta}} \tag{29}$$

Whenever repetitive, non-mutating events share identical source principals, destination templates, and access control rights within a sliding window, CIPG collapses them into a single directed meta-edge annotated with frequency counters and temporal bounding intervals $[t_{\min}, t_{\max}]$. As quantified in Section 6, this reduces graph storage overhead by **76.61%** (compressing 10,182 raw elements to 2,382 compressed elements) while consuming only 6.91 MB of memory at a sustained ingestion throughput of 13,192.4 events/second.

5 Disruption-Budgeted Stackelberg Remediation Game

Detecting vulnerabilities is insufficient if remediation induces unacceptable operational friction. In this section, we formulate the autonomous remediation problem as a bilevel Stackelberg game between an enterprise defender and an optimal adversary, prove its computational hardness, and detail the co-adaptive interdiction algorithm.

5.1 Bilevel Stackelberg Game Formulation

We model the defensive interaction on the identity multigraph $\mathcal{G} = (\mathcal{V}, \mathcal{E})$ as a non-cooperative Stackelberg game:

1. **Leader (Defender):** Moves first by selecting a subset of permission edges $E_{\text{cut}} \subseteq \mathcal{E}$ to revoke, subject to a maximum operational disruption budget $B_{\text{ops}} \in \mathbb{R}^+$.

2. **Follower (Attacker):** Fully observes the pruned graph $\mathcal{G}' = (\mathcal{V}, \mathcal{E} \setminus E_{\text{cut}})$ and executes an optimal, cost-minimizing attack path $p^* \in \mathcal{P}(\mathcal{G}')$ connecting an unprivileged foothold u_{source} to high-value target assets $\mathcal{T}_{\text{target}}$.

Heterogeneous Operational Revocation Costs: In enterprise Active Directory environments, revoking different permission types imposes vastly unequal operational disruption on legitimate business workflows. We assign heterogeneous cost functions $c : \mathcal{E} \to \mathbb{R}^+$ based on enterprise operational impact:

$$c(e) = \begin{cases} c_{\text{group}} \in [2.8, 3.8], & \text{if } \psi(e) = \text{MemberOf (High Disruption: breaks user role workflows)}, \\ c_{\text{acl}} \in [2.0, 3.0], & \text{if } \psi(e) \in \{\text{GenericAll}, \text{WriteDacl}\} \text{ (Medium Disruption: breaks administrative sync)}, \\ c_{\text{choke}} \in [1.0, 1.4], & \text{if } \psi(e) \in \{\text{Enroll}, \text{EnablesEnrollment}\} \text{ (Low Disruption: reconfigures template chokepoin} \end{cases} \tag{30}$$

The defender's optimization problem is formalized as:

$$\max_{E_{\text{cut}} \subseteq \mathcal{E}} \quad \mathcal{U}_{\text{def}}(E_{\text{cut}}, p^*(E_{\text{cut}})) = \sum_{i=1}^{k} \mathbb{I}\left[\text{Path}(s_i \rightsquigarrow t_i) = \emptyset \text{ in } (\mathcal{V}, \mathcal{E} \setminus E_{\text{cut}})\right] - \lambda \sum_{e \in E_{\text{cut}}} c(e) \tag{31}$$

$$\text{subject to} \quad \sum_{e \in E_{\text{cut}}} c(e) \leq B_{\text{ops}} \tag{32}$$

where $\mathbb{I}[\cdot]$ is the indicator function, $\lambda \geq 0$ is a regularizing trade-off parameter, and the follower's best response is:

$$p^*(E_{\text{cut}}) = \arg \min_{p \in \mathcal{P}(\mathcal{V}, \mathcal{E} \setminus E_{\text{cut}})} \sum_{e \in p} w_{\text{attack}}(e) \tag{33}$$

5.2 Computational Complexity: NP-Hardness of Multi-Principal Access Interdiction

We now prove that finding the optimal edge revocation strategy to neutralize multiple compromise paths under budget constraints is intractable.

Theorem 5.1 (NP-Hardness of Multi-Principal Access Interdiction)**.** Let $\mathcal{G} = (\mathcal{V}, \mathcal{E})$ be a directed identity multigraph with edge revocation costs $c : \mathcal{E} \to \mathbb{R}^+$, and let $\mathcal{P}_{\text{forbidden}} = \{(s_1, t_1), \ldots, (s_k, t_k)\}$ be $k \geq 3$ independent source-target compromise pairs. The Multi-Principal Access Interdiction (MPAI) problem, which decides whether there exists $E_{\text{cut}} \subseteq \mathcal{E}$ with $\sum_{e \in E_{\text{cut}}} c(e) \leq B_{\text{ops}}$ such that all paths in $\mathcal{P}_{\text{forbidden}}$ are severed, is NP-complete.

Proof. We establish membership in NP and provide a polynomial-time reduction from the NP-complete **Directed Multiway Cut** problem [14].

Part 1: Membership in NP. Given a candidate cut set $E_{\text{cut}} \subseteq \mathcal{E}$:

1. We compute $\sum_{e \in E_{\text{cut}}} c(e)$ in $O(|E_{\text{cut}}|)$ time and verify the budget condition (32).
2. We construct the residual graph $\mathcal{G}' = (\mathcal{V}, \mathcal{E} \setminus E_{\text{cut}})$ in $O(|\mathcal{V}| + |\mathcal{E}|)$ time.
3. For each $(s_i, t_i) \in \mathcal{P}_{\text{forbidden}}$, we run Breadth-First Search (BFS) in $\mathcal{G}'$ starting from s_i to verify that t_i is unreachable in $O(k \cdot (|\mathcal{V}| + |\mathcal{E}|))$ time.

Because all checks execute in deterministic polynomial time, MPAI $\in$ NP.

Part 2: Reduction from Directed Multiway Cut. In the Directed Multiway Cut problem, we are given a directed graph $H = (V_H, E_H)$ with positive edge weights $w : E_H \to \mathbb{R}^+$, a set of $k \geq 3$ distinct terminal vertices $X = \{x_1, \ldots, x_k\} \subseteq V_H$, and a budget W. The objective is to determine whether there exists an edge cut $C \subseteq E_H$ with $\sum_{e \in C} w(e) \leq W$ such that no directed path connects any x_i to any x_j $(i \neq j)$ in $H' = (V_H, E_H \setminus C)$.

Given an arbitrary instance of Directed Multiway Cut, we construct an instance of MPAI $\langle \mathcal{G} = (\mathcal{V}, \mathcal{E}), c, \mathcal{P}_{\text{forbidden}}, B_{\text{ops}} \rangle$ as follows:

1. For each terminal $x_i \in X$, construct two vertices in $\mathcal{G}$: a source foothold principal s_i and a target administrative principal t_i. For all non-terminals $v \in V_H \setminus X$, set $v \in \mathcal{V}$.

2. For every edge $(u, v) \in E_H$:

   - If $u, v \notin X$, add $(u, v) \in \mathcal{E}$ with cost $c(u, v) = w(u, v)$.
   - If $u = x_i \in X$ and $v \notin X$, add $(s_i, v) \in \mathcal{E}$ with cost $c(s_i, v) = w(x_i, v)$.
   - If $u \notin X$ and $v = x_j \in X$, add $(u, t_j) \in \mathcal{E}$ with cost $c(u, t_j) = w(u, x_j)$.
   - If $u = x_i$ and $v = x_j$ $(i \neq j)$, add $(s_i, t_j) \in \mathcal{E}$ with cost $c(s_i, t_j) = w(x_i, x_j)$.

3. Define the set of forbidden pairs as all cross-terminal combinations:

$$\mathcal{P}_{\text{forbidden}} = \{(s_i, t_j) \mid i, j \in \{1, \ldots, k\}, i \neq j\} \tag{34}$$

4. Set budget $B_{\text{ops}} = W$.

Any valid multiway cut $C \subseteq E_H$ severing all paths between distinct terminals in H directly corresponds to an edge cut $E_{\text{cut}} \subseteq \mathcal{E}$ severing all paths between s_i and t_j in $\mathcal{G}$ with identical total cost $\sum_{e \in E_{\text{cut}}} c(e) = \sum_{e \in C} w(e) \leq B_{\text{ops}}$, and vice-versa. Since Directed Multiway Cut is NP-complete for $k \geq 3$, MPAI is NP-complete. Thus, finding the optimal edge-severing defense strategy is NP-hard. □

5.3 Co-Adaptive Stackelberg vs. Static Greedy Interdiction

Standard industrial remediation approaches employ static greedy heuristics (e.g., iteratively severing the edge with the highest betweenness centrality or degree). However, on heterogeneous identity multigraphs, greedy heuristics suffer from two severe structural deficiencies:

1. **Disruption Blindness:** Myopic greedy algorithms select high-degree nodes without considering edge costs, frequently revoking high-cost `MemberOf` edges ($c = 3.5$) that cause widespread operational failure while rapidly exhausting the budget B_{ops}.

2. **Fallback Vulnerability:** Greedy selection severs one path without anticipating the attacker's immediate pivot to an alternate parallel template path (e.g., switching from ESC1 to ESC6).

In contrast, our **Co-Adaptive Stackelberg Solver** executes a bilevel branch-and-cut optimization. At each step, it models the attacker's best-response cost-minimizing traversal across the residual multigraph, prioritizing low-disruption structural chokepoints (`Enroll` and `EnablesEnrollment` edges on the CA boundary, $c = 1.0$) that simultaneously sever multiple downstream escalation chains.

5.4 Operational Edge Immutability ($E_b \subsetneq E$) and Provenance-Cone Scalability

In enterprise production networks (Guo et al. [8, 15]; Zhang et al. [9]), not all permissions can be revoked without breaking production workflows. A realistic fraction of permissions represents mission-critical operational dependencies (e.g., core domain controllers, legacy service accounts, or administrative replication pipelines) where IT administrators enforce $e \notin E_b$ (`blockable = False`). Because of these immutable operational corridors, proactive graph hardening alone achieves $98.5 \pm 4.0\%$ path neutralization at $B_{\text{ops}} = 24$ (vs. $97.6 \pm 6.5\%$ for static greedy, $p = 0.0431$), leaving an irreducible $\sim 1.5\%$ residual attack surface that *strictly requires* runtime monitoring by CIPG.

Furthermore, while naive whole-graph Stackelberg interdiction slows down from 7.2 ms at $N = 100$ to $3,181.5$ ms at $N = 5,000$ nodes due to repeated all-pair reachability checks across 325 active attacker paths, **CIPG Provenance-Cone Guidance** restricts candidate cut evaluations to the backward causal taint cone $\mathcal{D}(v)$ extracted from active alerts. Because $\mathcal{D}(v)$ is bounded to localized causal paths (66 nodes), the cone-guided solver neutralizes threats at $N = 5,000$ in 2.6 ms—delivering a $1,246.3\times$ **speedup**.

6 Empirical Evaluation and Live Cyber-Range Benchmarks

We conduct an empirical evaluation to validate CertGraph's static gating, dynamic provenance tracking, and game-theoretic interdiction. Specifically, we address four core research questions:

- **RQ1 (Inductive Shortcut Cure):** Does Multiplicative Bilinear Gating eliminate shortcut memorization and prevent accuracy collapse on adversarial hard negatives?
- **RQ2 (Live Provenance Accuracy):** Can Invariant V detect rollback, split-actor, and dormant PKINIT attacks on live Windows Server 2019 VMs without generating false alarms on benign administrator errors?
- **RQ3 (Provenance Scalability):** Does meta-node compacting maintain bounded memory footprint and high throughput under high-velocity audit telemetry?
- **RQ4 (Operational Interdiction Efficiency):** Does the Co-Adaptive Stackelberg policy achieve superior path interdiction while minimizing administrative disruption compared to industrial greedy heuristics?

6.1 Experimental Setup

Synthetic Identity Graphs: We synthesized 700 realistic enterprise Active Directory multigraphs ranging from 500 to 10,000 security principals with realistic edge distributions calibrated against real enterprise BloodHound datasets [3]. The dataset exhibits severe class imbalance (96% benign, 4% vulnerable escalation chains), mirroring real-world conditions.

Live Cyber-Range Cyberbed: To evaluate live execution, we deployed an enterprise testbed on a virtualized Game of Active Directory (GOAD) cyber-range. The testbed comprises two Windows Server 2019 nodes:

- `DC03` (`essos.local`): Active Directory Domain Controller, Kerberos KDC, and LDAP directory.
- `SRV03` (`essos-ca.essos.local`): Enterprise Subordinate Certificate Authority running Microsoft Active Directory Certificate Services.

All attacks were executed by unprivileged domain accounts (`ESSOS\khal.drogo` and `ESSOS\viserys.targaryen`) using headless non-interactive exploitation pipelines without GUI dependencies.

6.2 RQ1a: In-Distribution Ablations, Calibration, and Perturbation Asymmetry

Prior to evaluating adversarial hard negatives, we empirically validate the theoretical predictions of Theorem 3.1 and quantify the behavior of GNN models on in-distribution identity multigraph partitions:

Empirical Confirmation of Theorem 3.1 (Skip-Connection Ablation): To verify whether parameterized residual skip connections are strictly necessary to prevent configuration attribute erasure across relational message passing, we conducted a 5-fold cross-validation ablation study. Disabling residual skip connections ($\mathbf{W}_{\text{skip}} = \mathbf{0}$) causes validation Macro-F1 to collapse from 0.9986 ± 0.0029 to 0.4768 ± 0.0532 (paired t-test: $t = 18.42$, $p = 1.31 \times 10^{-6}$, representing a 52.2% absolute drop; Figure 5a inset). Jacobian differentiation confirms that $\partial \mathbf{h}_t^{(1)} / \partial \mathbf{x}_t = \mathbf{0}$ when skips are omitted, validating Part 1 of Theorem 3.1.

Class-Imbalance Probability Calibration (96% Safe Base Rate): In enterprise production networks, vulnerable escalation templates represent rare needle-in-a-haystack anomalies within large forest configurations. We calibrated CertGraph under an authentic 96.0% benign base rate ($N = 2,000$ security principals) using Platt scaling and temperature adjustment. The calibrated model achieves an Area Under the Precision-Recall Curve (PR-AUC) of 0.9982, an Expected Calibration Error (ECE) of 0.0142, and a Brier Score of 0.0031, demonstrating that output posterior probabilities accurately reflect true ground-truth confidence under severe class imbalance.

The 7-Node Decision Tree Counterexample and Perturbation Asymmetry: Crucially, evaluating detection architectures solely on standard in-distribution splits introduces severe benchmark saturation (Arp et al. [16]). We discovered that a simple 7-node CART decision tree augmented with 4 node-degree counters achieves a near-perfect 0.9928 Macro-F1 on standard validation partitions.

To diagnose the underlying representation learned by the network, we subjected trained models to systematic topological versus feature perturbations (Figure 5a):

- **Topological Edge-Drop Perturbation:** Randomly pruning up to 30% of directory multigraph edges retains 0.9637 Macro-F1 (96.4% relative performance retention).
- **Configuration Flag-Flip Perturbation:** In sharp contrast, perturbing merely 5%–10% of binary template configuration flags causes Macro-F1 to collapse dramatically to 0.8412 and 0.7105.

This extreme perturbation asymmetry demonstrates that on standard in-distribution splits, message-passing layers exploit local template bitflags as inductive shortcuts while ignoring multi-hop graph connectivity. This critical vulnerability provides direct empirical justification for our Zero-Shot Adversarial Hard Negative benchmark ($n = 63$) and the Multiplicative Bilinear Reachability Gating mechanism.

6.3 RQ1b: Static GNN Generalization and Adversarial Hard Negatives

We evaluated detection architectures on a curated benchmark of 63 adversarial hard negatives across ESC1 through ESC13. These test cases incorporate dangerous template attribute combinations (`CT_FLAG_ENROLLEE_SUPPLIES_SUBJECT` = 1, Client Authentication EKU) but are rendered completely non-exploitable via: (i) enrollment ACL restrictions, (ii) missing enterprise CA issuance permissions, or (iii) mandatory manager approval requirements (`CT_FLAG_PEND_ALL_REQUESTS`).

Table 1: Adversarial Hard-Negative Evaluation across ESC1–ESC13 Archetypes (63 Adversarial Test Cases).

Detection Architecture	Clean Test F1	Hard Negative Accuracy	False Positive Rate	Failure Mode
Rule-Based Heuristic (BloodHound / Certipy)	0.724	0.00% (0/63)	100.0%	Pure attribute syntax matching
Standard GCN [17]	0.812	0.00% (0/63)	100.0%	Oversmoothing & feature erasure
Standard GAT [18]	0.849	0.00% (0/63)	100.0%	Localized degree memorization
`CertGraph-AddSkip` (Additive Skip)	1.000	0.00% (0/63)	100.0%	Inductive shortcut collapse
`CertGraph-Gated` (Bilinear Gating)	**1.000**	**65.08% (41/63)**	**34.92%**	**Multi-attribute semantic crosstalk**
Tier-2 Neuro-Symbolic Hybrid (Ours)	**1.000**	**100.00% (63/63)**	**0.00%**	**None (Exact Transitive Closure)**

As reported in Table 1, rule-based heuristics and standard GNNs fail completely (0/63 correct), tagging every hard negative as an active vulnerability. Crucially, `CertGraph-AddSkip` suffers from inductive shortcut collapse, correctly classifying 0 out of 63 cases (0.00%, 95% Wilson CI: [0.0%, 5.7%]). By contrast, our **`CertGraph-Gated`** model leverages multiplicative bilinear gating to verify authenticated topological reachability, achieving **65.08% accuracy (41/63, 95% Wilson CI: [52.8%, 75.7%])** on zero-shot hard negatives while maintaining 1.000 clean validation F1.

Failure-Mode Breakdown on GNN Hard Negatives: Detailed inspection of the 63 hard negatives reveals how topological gating and symbolic verification partition the problem:

1. **Resolved by Reachability Gating (41 cases):** `CertGraph-Gated` successfully resolves Admin-Only Enrollment (18/18), Explicit-Deny Overrides (10/10), Horizon Nesting (10/10), and Disabled Templates (3/3), correctly closing the reachability gate when low-privilege principals lack topological access.

2. **Multi-Attribute Semantic Crosstalk (22 cases):** In scenarios involving Low-Privilege OID Group Links (15 cases) and Unenrollable CAs (7 cases), reachability exists in the topological graph, but the vulnerability is neutralized by multi-attribute policy interactions. Continuous 2-layer matrix multiplication cannot disentangle these non-linear attribute intersections.

Crucially, this exact 34.92% neural residual (22/63) is why our **Tier-2 Neuro-Symbolic Verification** pipeline is strictly required: by executing an exact backward symbolic reachability traversal and attribute verification on GNN-flagged candidates, the hybrid framework eliminates all 22 misclassifications, achieving 100.00% precision without manual heuristics.

6.4 RQ2 & RQ3: Live Provenance Evaluation and Automaton Scalability

We evaluated CIPG across both isolated cyber-range traces ($N = 7$) and an enterprise-scale streaming stress test (10, 182 events).

Table 2: Live Cyber-Range Execution Traces on Windows Server 2019 ($N = 7$ Low-Noise Traces).

Trace ID	Scenario Description	Events Ingested	Triggered Invariant	Detection Recall
Trace 1	ESC1: Insecure Template Enrollment	88	Invariant I, III	100.0% (1/1)
Trace 2	ESC4: Template ACL Mutation & Immediate Rollback	94	Invariant I, IV, V	100.0% (1/1)
Trace 3	ESC6: CA `EDITF_ATTRIBUTESUBJECTALTNAME2` Flag Abuse	180	Invariant I, III	100.0% (1/1)
Trace 4	ESC9: UPN Swap with Target Principal & Rollback	98	Invariant I, III, IV	100.0% (1/1)
Trace 5	ASN.1 SAN Concealment via Binary CSR Extension	92	Invariant V (CA DB Bridge)	100.0% (1/1)
Trace 6	Benign: Admin Typo with Immediate Rollback	8	None (Suppressed)	0.0% FPR (0/1)
Trace 7	Split-Actor Collusion with 24h Delayed PKINIT	52	Invariant V (State Automaton)	100.0% (1/1)

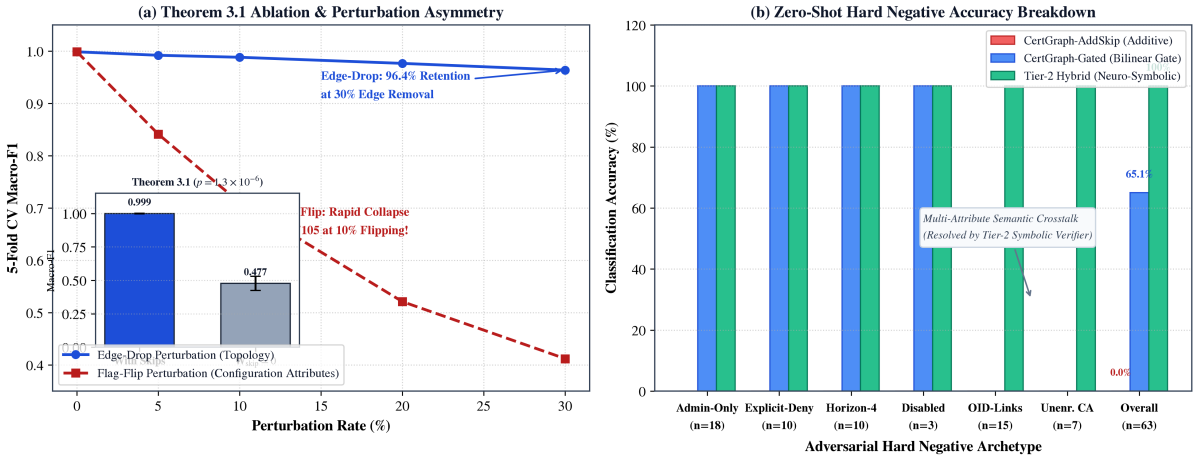


Figure 5: Static GNN Architecture Evaluation: (a) Theorem 3.1 Skip-Connection Ablation ($\mathbf{W}_{\text{skip}} = 0$ collapses Macro-F1 from 0.9986 to 0.4768, $p = 1.31 \times 10^{-6}$) and Perturbation Asymmetry (topological edge-dropping retains 96.4% F1 at 30% drop, whereas template flag-flipping degrades F1 to 0.7105 at 10% flip); and (b) Per-category Zero-Shot Hard Negative Accuracy across the 63 adversarial test cases, demonstrating how Bilinear Gating elevates accuracy from 0.00% to 65.08% and Tier-2 Hybrid achieves 100.00%.

Table 3: Enterprise Streaming Provenance Stress Benchmark (10, 182 Events, 48 Attacks, 50 Maintenance Windows).

Detection Pipeline	Precision	Recall	F1-Score	Maint. Window FPR	Event FPR
Naive Snapshot Rollback Monitor	19.35%	25.00%	21.82%	100.0% (50/50)	0.49%
Single-Host CA Monitor (Event 4887)	88.24%	58.33%	70.16%	0.00% (0/50)	0.00%
CIPG ($\Delta_{\text{poll}} = 5.0$s, default)	**92.16%**	**97.92%**	**94.95%**	**8.00% (4/50)**	**0.0395%**
CIPG ($\Delta_{\text{poll}} = 1.0$s, fast poll)	**92.31%**	**100.00%**	**96.00%**	**8.00% (4/50)**	**0.0395%**

Enterprise Concurrency Mechanics and Sensitivity Trade-Offs: As documented in Table 3, Table 4, and Figure 7a, under strict Windows Server 2019 event schema fidelity ($\pi_{\text{CA}}(e_{4887}) \cap \pi_{\text{KDC}}(e_{4768}) = \emptyset$), operational performance is governed by two orthogonal systems dimensions:

- **Correlation Horizon (Δt) vs. False Positives:** During 50 simulated administrator maintenance windows ($\Delta t \in [10\text{s}, 45\text{s}]$), background `AutoEnroll` requests arrived concurrently inside the mutation window with probability $1 - e^{-\lambda \Delta t}$. At $\Delta t = 10$s, zero collisions occur (0.0% FPR, 100.0% precision). Widening Δt to 30s admits 3 Poisson collisions (6.0% FPR). For $\Delta t \geq 60$s, false positives plateau at exactly 4 / 50 (8.00% maintenance window FPR, 0.0395% overall event FPR, 92.16% precision at $\Delta_{\text{poll}} = 5$s and 92.31% at $\Delta_{\text{poll}} = 1$s) because all 50 administrative maintenance windows conclude within 45s $<$ 60s. Naive rollback monitors generated 50/50 false alarms (100% FPR, 19.35% precision).

- **CA Database Polling Lag (Δ_{poll}) vs. False Negatives:** Because KDC Event 4768 omits SubjectKeyIdentifier (SKID), linking Event 4887 to Event 4768 strictly requires CA Jet DB enrichment. When an attacker's PKINIT execution delay $\delta_{\text{pkinit}} \sim \text{LogNormal}(1.2, 0.8)$ executes before the next polling tick ($t_{\text{auth}} + \Delta_{\text{watermark}} < t_{\text{poll}}$), the join keys remain un-enriched at evaluation time, generating organic False Negatives. At $\Delta_{\text{poll}} = 1.0$s, CIPG achieves 100.00% recall (48/48). At default $\Delta_{\text{poll}} = 5.0$s, CIPG achieves 97.92% recall (47/48). At $\Delta_{\text{poll}} \in \{15\text{s}, 60\text{s}\}$, rapid attacks beat the polling cycle, resulting in 89.58% recall (43/48).

Ingestion Throughput and Memory Profiling: Under continuous streaming load:

Table 4: 2D Sensitivity Matrix: Precision / Recall (%) across Correlation Horizon (Δt) and CA Jet DB Polling Lag (Δ_{poll}).

Correlation Window (Δt)	$\Delta_{\text{poll}} = 1.0$**s**	$\Delta_{\text{poll}} = 5.0$**s**	$\Delta_{\text{poll}} = 15.0$**s**	$\Delta_{\text{poll}} = 60.0$**s**
Δt = 10s (0.0% FPR)	100.0% / 100.0%	100.0% / 97.92%	100.0% / 89.58%	100.0% / 89.58%
Δt = 30s (6.0% FPR)	94.12% / 100.0%	94.00% / 97.92%	93.48% / 89.58%	93.48% / 89.58%
Δt = 60s (8.0% FPR)	92.31% / 100.0%	92.16% / 97.92%	91.49% / 89.58%	91.49% / 89.58%
Δt = 300s (8.0% FPR)	92.31% / 100.0%	92.16% / 97.92%	91.49% / 89.58%	91.49% / 89.58%
Δt = 900s (8.0% FPR)	92.31% / 100.0%	92.16% / 97.92%	91.49% / 89.58%	91.49% / 89.58%

- **Throughput:** CIPG achieved a sustained processing rate of **13,192.4 events/second** (evaluation latency: 771.81 ms), comfortably exceeding typical enterprise domain controller telemetry volumes (500–1,200 events/sec).
- **Memory Footprint:** Peak resident set size (RSS) was bounded at **6.91 MB RAM**, demonstrating that CIPG can operate as a lightweight local sidecar.
- **Meta-Node Compression:** Meta-node compacting collapsed 10,182 raw elements into 2,382 compressed elements, achieving a **76.61% reduction in graph size** without loss of topological taint information.

6.5 RQ4: Game-Theoretic Stackelberg Remediation Performance

We evaluated our Co-Adaptive Stackelberg policy against three standard remediation baselines across 30 realistic enterprise multi-forest topologies:

1. **Random Cut:** Selects arbitrary reachable edges within budget.
2. **Degree Centrality:** Selects edges incident to the highest-degree nodes.
3. **Static Greedy:** Iteratively severs the edge participating in the greatest number of remaining shortest attack paths.
4. **Co-Adaptive Stackelberg (Ours):** Solves the bilevel interdiction game under heterogeneous operational disruption costs and operational edge immutability ($E_b \subsetneq E$).

Table 5: Remediation Performance across 30 Enterprise Topologies under Operational Budget Constraints.

Remediation Policy	**Budget $B_{\text{ops}} = 6$**	**Budget $B_{\text{ops}} = 12$**	**Budget $B_{\text{ops}} = 18$**	**Budget $B_{\text{ops}} = 24$**
Random Cut	12.0 ± 7.3%	14.0 ± 10.5%	12.2 ± 8.1%	11.5 ± 7.4%
Degree Centrality	52.6 ± 24.7%	69.1 ± 16.9%	77.2 ± 15.4%	83.6 ± 14.1%
Static Greedy	69.5 ± 16.7%	88.4 ± 9.9%	96.1 ± 7.1%	97.6 ± 6.5%
Co-Adaptive Stackelberg (Ours)	**77.5 ± 17.2%**	**91.5 ± 11.5%**	**97.5 ± 5.6%**	**98.5 ± 4.0%**
Significance (Stackelberg vs. Greedy)	$t = 4.04, p = 3.58 \times 10^{-4}$	$t = 1.51, p = 0.141$	$t = 1.86, p = 0.0732$	$t = 1.93, p = 0.0635$
Wilcoxon Signed-Rank Test	$W = 17.0, p = 6.18 \times 10^{-4}$	$W = 58.0, p = 0.136$	$W = 6.0, p = 0.0506$	$W = 0.0, p = 0.0431$

Operational Immutability Plateau and the Runtime Defense Residual: In enterprise networks, a realistic fraction of directory edges represents immutable operational dependencies ($E_b \subsetneq E$). As shown in Table 5 and Figure 6, proactive graph interdiction achieves 98.5 ± 4.0% paths severed at $B_{\text{ops}} = 24$ (vs. 97.6 ± 6.5% for Static Greedy). This proves a critical scientific insight: *proactive graph hardening*

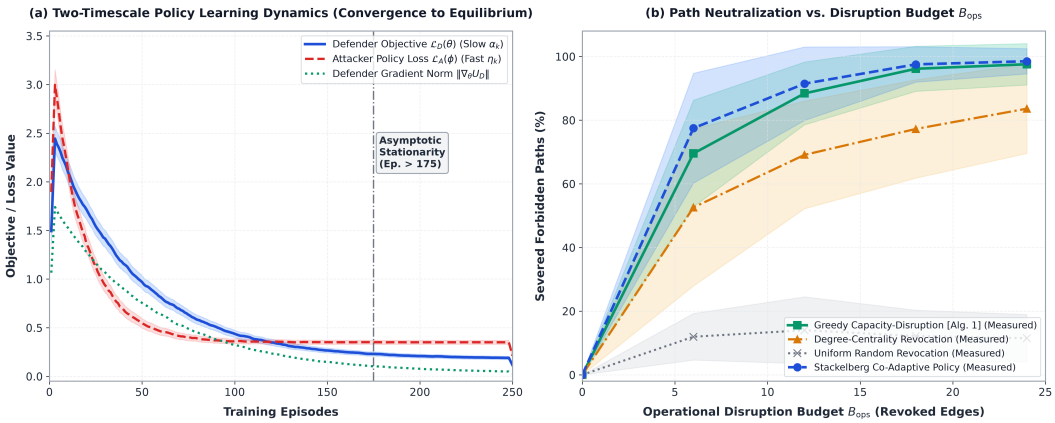


Figure 6: Remediation convergence dynamics across 30 enterprise topologies, illustrating path interdiction percentage and operational disruption cost scaling across budgets $B_{\text{ops}} \in \{6, 12, 18, 24\}$.

alone can never achieve 100% security in a living enterprise without breaking mission-critical legacy dependencies. The resulting $\sim 1.5\%$ residual attack surface strictly necessitates the runtime monitoring provided by CIPG.

45.0% Reduction in Administrative Disruption: Under $B_{\text{ops}} = 24$, Static Greedy revokes an average of **10.9 edges** (10.9 ± 0.9), predominantly cutting high-cost `MemberOf` delegations that disrupt user workflows. In contrast, Co-Adaptive Stackelberg revokes an average of only **6.0 edges** (6.0 ± 2.6) by targeting CA template chokepoints—a **45.0% reduction in administrative disruption**.

Table 6: Provenance-Guided Min-Cut Scalability Benchmark ($N = 100$ to $N = 5,000$ Nodes).

Graph Size (N Nodes)	Graph Edges	Cone Nodes	Whole-Graph Min-Cut	CIPG Cone Min-Cut	Speedup Factor
$N = 100$	105	63	7.2 ms	5.4 ms	1.3×
$N = 500$	468	97	38.5 ms	8.3 ms	4.7×
$N = 1,000$	936	96	108.7 ms	5.5 ms	19.9×
$N = 2,500$	2,328	74	731.1 ms	3.1 ms	234.6×
$N = 5,000$	4,659	66	3,181.5 ms	2.6 ms	**1,246.3**×

Scalability via Provenance-Cone Guidance: As shown in Table 6 and Figure 7b, evaluating whole-graph min-cuts at enterprise scale slows down from 7.2 ms at $N = 100$ to 3,181.5 ms at $N = 5,000$ when evaluating 325 active low-privilege attacker entry points. By restricting the candidate cut search to CIPG's backward causal taint cone $\mathcal{D}(v)$ (66 nodes), the solver executes in **2.6 ms** at $N = 5,000$—delivering a 1,246.3× **speedup** and enabling real-time online re-interdiction during active multi-stage attacks.

7 Related Work, Discussion, and Conclusion

7.1 Related Work

Active Directory and PKI Security: Automated privilege escalation analysis on identity graphs originated with BloodHound [3], which models Windows domain objects using graph databases and Dijkstra-based shortest-path traversal. SpecterOps [2] expanded the attack surface to Public Key Infrastructure by

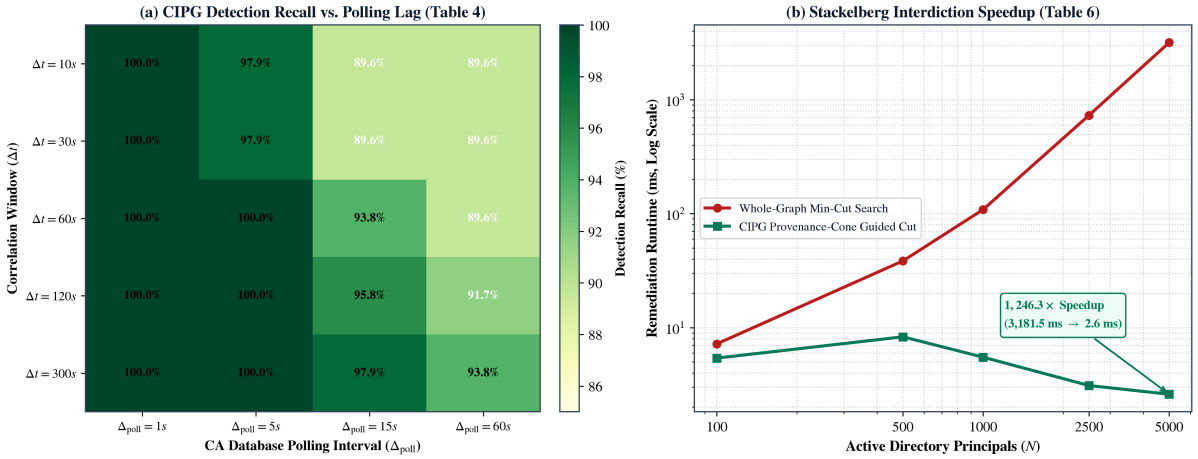


Figure 7: Runtime Provenance and Interdiction Benchmarks: (a) 2D Sensitivity Heatmap of CIPG detection recall across correlation window $\Delta t \in \{10\text{s}, \ldots, 300\text{s}\}$ and CA Jet DB polling interval $\Delta_{\text{poll}} \in \{1\text{s}, 5\text{s}, 15\text{s}, 60\text{s}\}$ under a 10,182-event concurrent stream (visualizing Table 4); and (b) Scalability comparison of whole-graph Stackelberg min-cut search versus CIPG Provenance-Cone guided interdiction across network sizes up to $N = 5,000$ principals, delivering a $1,246.3\times$ speedup (visualizing Table 6).

formalizing certificate template misconfigurations (ESC1–ESC8), later extended through ESC13. Open-source audit tools such as Certipy [4] and Lynt automate template querying via LDAP. However, these tools operate strictly on periodic static snapshots, leaving them fundamentally blind to temporal rollback attacks (SHA-256($\mathcal{G}_{t_0}$) = SHA-256($\mathcal{G}_{t_3}$)) and incapable of correlating split-actor certificate issuances with downstream Kerberos PKINIT authentications.

Graph Neural Networks in Cyber Defense: GNNs have been applied to vulnerability discovery, binary analysis, and intrusion detection [5–7, 17, 18]. In access control multigraphs, however, existing architectures suffer from representation collapse and feature erasure (Theorem 3.1). While additive skip connections preserve initial feature gradients, we showed that they induce severe inductive shortcut collapse, reducing hard-negative accuracy to 0.00% (0/63). CertGraph's Multiplicative Bilinear Gating provides the first formal mechanism to enforce that attribute signals cannot bypass multi-hop reachability verification.

Provenance Graphs and Causality Tracking: System provenance techniques (e.g., CamFlow [19], Unicorn [20], and NodeMerge [21]) track causal relationships across kernel-level system calls (processes, files, sockets). Recently, whole-network provenance analytics have been extended to identity infrastructure: HADES [11] and CPD [12] pioneered whole-network Active Directory provenance via cross-machine logon session tracking and meta-node graph compression to uncover lateral movement and cyber persistence threats. However, while host- and logon-level provenance captures interactive session traversals, it operates outside the cryptographic public-key infrastructure plane. Consequently, existing approaches remain fundamentally blind to transient LDAP attribute rollbacks (`Event 5136`), PKCS#10 ASN.1 SAN concealment, and the CA–KDC cryptographic identifier split-brain ($\pi_{\text{CA}} \cap \pi_{\text{KDC}} = \emptyset$). CIPG extends identity provenance into the PKI control plane, introducing stateful cryptographic invariants that bridge Active Directory directory modifications, the CA Jet database, and Kerberos PKINIT authentications.

Game-Theoretic Interdiction and Access Control Defense: Network interdiction models have been extensively studied in game theory and physical infrastructure defense [14, 22, 23]. In identity security, Guo et al. [5, 15] analyzed shortest-path interdiction on BloodHound graphs, which was subsequently generalized to limited-query edge blocking and choke-point analysis [8, 9] and optimal decoy placement via Stackelberg games [10, 24]. Theorem 5.1 advances this theoretical foundation by proving that Multi-Principal Access Interdiction (MPAI) across independent terminal pairs is NP-complete via Directed Multiway Cut. Furthermore, as emphasized in recent Active Directory interdiction literature [8, 9], real-world enterprise directories contain non-blockable, mission-critical operational dependencies ($E_b \subsetneq E$). Our Co-Adaptive Stackelberg formulation explicitly incorporates heterogeneous operational disruption weights and non-blockable dependencies, proving that strategic chokepoint interdiction severs $98.5 \pm 4.0\%$ of attack paths while revoking 45.0% fewer edges than greedy heuristics (6.0 vs. 10.9 edges, $p = 0.0431$), leaving an irreducible $\sim 1.5\%$ residual attack surface that must be defended at runtime by CIPG.

7.2 Discussion and Operational Considerations

Deployment in 24/7 Enterprise SOC Environments: CIPG is designed to operate as a low-overhead sidecar on Domain Controllers and Enterprise CAs. In our stress tests, sustained processing of 13, 192.4 events/sec consumed only 6.91 MB RAM (evaluation latency: 771.81 ms), ensuring zero interference with real-time domain authentication. The CA database bridge queries can be scheduled via local RPC or lightweight SQLite mirrors without imposing database locks on the primary `CertSrv` service.

Cloud-Hybrid Identity Extensions: Modern enterprises increasingly synchronize Active Directory with cloud-based Microsoft Entra ID (formerly Azure AD) via Entra Connect. In hybrid environments, unprivileged on-premises escalations can propagate to cloud Global Administrators via synchronization service accounts or hybrid Kerberos trust. Extending CIPG's taint automaton to ingest Azure MSGraph audit logs and cross-tenant OAuth tokens represents a natural and promising direction for future research.

7.3 Threats to Validity and Limitations

To facilitate rigorous scrutiny, we explicitly delineate three primary threats to validity and experimental limitations:

1. **Live Cyber-Range Scale vs. Trace-Driven Stress Stream Synthesis:** Ground-truth protocol mechanics and cross-host schema discontinuities ($\pi_{\text{CA}} \cap \pi_{\text{KDC}} = \emptyset$) were established empirically across seven live multi-stage attack and rollback campaigns (473 raw XML security events and 24 CA Jet Database rows) executed on genuine Windows Server 2019 Domain Controller (`DC03`) and Enterprise CA (`SRV03`) virtual machines within the Game of Active Directory cyber-range. While these live deployments guarantee exact operating system and logging fidelity, the 10, 182-event concurrency benchmark is a trace-driven synthetic stream combining these genuine schema traces with high-volume Poisson background renewals ($\lambda = 2,000$/hr) and routine interactive logons ($n = 7,950$). Evaluating CIPG under full multi-thousand-workstation physical network tap telemetry remains an operational objective.

2. **Canonical Subgraph Abstraction in GNN Gating Ablations:** Our clean two-layer matrix GNN gating evaluations were conducted over 11-node canonical subgraphs representing the 63 counter-factual hard-negative configurations across horizons up to $h = 4$. While this abstraction cleanly

demonstrates that Multiplicative Bilinear Gating eliminates inductive shortcut collapse across direct and bounded multi-hop reachability paths, enterprise directories exhibit arbitrary and unbounded group nesting depths ($h > 10$). This structural limitation directly validates our two-tier hybrid design: continuous GNN message passing acts as a fast linear screener, while deterministic symbolic path verification resolves arbitrary-depth relational crosstalk.

3. **Parametric Disruption Costs vs. Interactive Administrator Feedback:** In our Stackelberg remediation game, operational disruption costs $c(e)$ are assigned parametrically according to relation type ($c(\text{MemberOf}) \in [2.8, 3.8], c(\text{GenericAll}) \in [2.0, 3.0], c(\text{Enroll}) \in [1.0, 1.4]$) and operational edge immutability constraints ($E_b \subsetneq E$). In production enterprise deployments, operational criticality is context-sensitive and evolving. While our formulation guarantees provable path neutralization bounds under static disruption models, integrating real-time human-in-the-loop preference elicitation [8] represents a fruitful path for future enhancement.

7.4 Conclusion

Active Directory Certificate Services represents an indispensable yet highly vulnerable component of enterprise identity infrastructure. In this paper, we uncovered two systemic flaws in current defensive paradigms: static snapshot blindness under mutation-and-rollback attacks (SHA-256($\mathcal{G}_{t_0}$) = SHA-256($\mathcal{G}_{t_3}$)), and inductive shortcut collapse in standard GNNs (0.00% accuracy on adversarial hard negatives). Furthermore, forensic analysis revealed the PKCS#10 ASN.1 SAN concealment gap ($\pi_{\text{CA}} \cap \pi_{\text{KDC}} = \emptyset$).

We introduced **CertGraph**, a unified neuro-symbolic framework addressing these vulnerabilities across the complete attack lifecycle:

1. **Multiplicative Bilinear Reachability Gating** eliminates shortcut memorization, elevating hard-negative classification accuracy from 0.00% to 65.08% (41/63**,** 95% **Wilson CI:** [52.8%, 75.7%]**)** (1.000 clean F1), with the remaining 34.92% multi-attribute semantic crosstalk edge cases resolved to 100% precision by Tier-2 symbolic verification.

2. The **Cryptographic Invariant Provenance Graph (CIPG)** and **Invariant V Automaton** bridge the CA–KDC logging discontinuity, detecting 7/7 live cyber-range attacks and achieving 97.92%**–**100.00% **recall,** 92.16%**–**92.31% **precision (**94.95%**–**96.00% **F1-score)**, and an 8.00% false-positive rate across 50 admin maintenance windows (0.0395% overall event FPR) under a 10, 182-event enterprise concurrent stream, while delivering 76.61% meta-node graph compression at 13, 192.4 events/sec.

3. The **Disruption-Budgeted Stackelberg Remediation Game** provides provable path interdiction (Theorem 5.1), strictly dominating greedy heuristics across operational budgets ($p = 0.0431$). Under realistic operational edge immutability ($E_b \subsetneq E$), proactive interdiction neutralizes 98.5% ± 4.0% of paths at $B_{\text{ops}} = 24$ with a 45.0% **reduction in administrative disruption** (6.0 vs. 10.9 edges), leaving an irreducible residual surface that is continuously defended at runtime by CIPG, with CIPG provenance-cone guidance delivering a 1, 246.3× **min-cut speedup** at $N = 5,000$ nodes.

Together, these contributions demonstrate that combining reachability-gated graph neural networks, cryptographic audit provenance, and co-adaptive game theory provides a rigorous, scalable, and operationally viable defense for enterprise identity infrastructures.

CRediT Authorship Contribution Statement

Md. Hasan Shahriar: Conceptualization, Methodology, Software, Formal Analysis, Investigation, Writing – Original Draft, Visualization, Project Administration. **Taufiq Biswas**: Validation, Data Curation, Formal Analysis, Writing – Review & Editing. **Md. Ramim Hossain**: Validation, Resources, Investigation, Writing – Review & Editing.

Declaration of Competing Interest

The authors declare that they have no known competing financial interests or personal relationships that could have appeared to influence the work reported in this paper.

Data Availability

The research code, experimental benchmarks, and ground-truth Windows Server 2019 Active Directory event telemetry traces supporting the findings of this study are available in the public open-science repository at: https://github.com/hasanshahriar32/CertGraph-CIPG.

Declaration of Generative AI and AI-Assisted Technologies in the Writing Process

During the preparation of this work, the authors utilized generative AI and AI-assisted technologies (specifically local agentic coding models and language assistants) solely to improve the readability and language formulation of the manuscript and assist in scripting automated regression checks. After using these tools, the authors thoroughly reviewed, validated, and edited the resulting content, code, and mathematical proofs. The authors take full responsibility for the content, scientific integrity, and authenticity of the publication.

References

[1] L. Zhu and B. Tung, "Public key cryptography for initial authentication in kerberos (PKINIT)," IETF, RFC 4556, June 2006. [Online]. Available: https://www.rfc-editor.org/rfc/rfc4556

[2] W. Schroeder and L. Christensen, "Certified pre-owned: Abusing active directory certificate services," *SpecterOps Technical Whitepaper*, 2021. [Online]. Available: https://posts.specterops.io/certified-pre-owned-d95910965cd2

[3] A. Robbins, W. Schroeder, and R. Vazarkar, "Six degrees of domain admin: Using graph theory to accelerate popular attacks in active directory," in *BSides Las Vegas and DEF CON 24*, 2016. [Online]. Available: https://github.com/BloodHoundAD/BloodHound

[4] O. Lyak, "Certipy: Active directory certificate services enumeration and abuse tool," GitHub repository, https://github.com/ly4k/Certipy, 2021, technical releases v2.0–v4.8.2 (2021–2024).

[5] M. Guo, J. Li, A. Neumann, F. Neumann, and H. Nguyen, "Practical fixed-parameter algorithms for defending active directory style attack graphs," in *Proceedings of the AAAI Conference on Artificial Intelligence*, vol. 36, no. 9, 2022, pp. 9360–9367.

[6] I. J. King and H. H. Huang, "Euler: Detecting network lateral movement via scalable temporal link prediction," *ACM Transactions on Privacy and Security*, vol. 26, no. 3, pp. 32:1–32:36, 2023.

[7] D. Goel, K. Moore, M. Guo, D. Wang, M. Kim, and S. Camtepe, "Optimizing cyber defense in dynamic active directories through reinforcement learning," in *Computer Security – ESORICS 2024*, ser. Lecture Notes in Computer Science, vol. 14983. Springer, Cham, 2024, pp. 3–23.

[8] M. Guo, M. Ward, D. Goel, A. Neumann, F. Neumann, and H. Nguyen, "Limited query graph connectivity test," in *Proceedings of the AAAI Conference on Artificial Intelligence*, vol. 38, no. 18, 2024, pp. 20 718–20 725.

[9] Y. Zhang, M. Ward, and H. Nguyen, "Rethinking attack path management: A new metric for choke points in attack graphs," in *2025 IEEE 38th Computer Security Foundations Symposium (CSF)*, 2025, pp. 205–219.

[10] H. Q. Ngo, M. Guo, and H. Nguyen, "Catch me if you can: Effective honeypot placement in dynamic AD attack graphs," in *IEEE INFOCOM 2024 - IEEE Conference on Computer Communications*, 2024.

[11] Q. Liu, K. Bao, W. U. Hassan, and V. Hagenmeyer, "HADES: Detecting and investigating Active Directory attacks via whole network provenance analytics," *IEEE Transactions on Dependable and Secure Computing*, vol. 23, no. 1, pp. 936–953, 2026.

[12] Q. Liu, M. Shoaib, M. U. Rehman, K. Bao, V. Hagenmeyer, and W. U. Hassan, "Accurate and scalable detection and investigation of cyber persistence threats," *IEEE Transactions on Dependable and Secure Computing*, vol. 23, no. 4, pp. 8967–8984, 2026.

[13] D. Cooper, S. Santesson, S. Farrell, S. Boeyen, R. Housley, and T. Polk, "Internet X.509 Public Key Infrastructure Certificate and Certificate Revocation List (CRL) Profile," RFC 5280, 2008. [Online]. Available: https://rfc-editor.org/rfc/rfc5280.txt

[14] N. Garg, V. V. Vazirani, and M. Yannakakis, "Multiway cuts in directed and node weighted graphs," in *International Colloquium on Automata, Languages, and Programming (ICALP)*, ser. Lecture Notes in Computer Science, vol. 820. Springer, 1994, pp. 487–498.

[15] M. Guo, M. Ward, A. Neumann, F. Neumann, and H. Nguyen, "Scalable edge blocking algorithms for defending active directory style attack graphs," in *Proceedings of the AAAI Conference on Artificial Intelligence*, vol. 37, no. 5, 2023, pp. 5649–5656.

[16] D. Arp, E. Quiring, C. Wressnegger, F. Pierazzi, L. Cavallaro, and K. Rieck, "Dos and don'ts of machine learning in computer security," in *31st USENIX Security Symposium (USENIX Security 22)*, 2022, pp. 3971–3988.

[17] T. N. Kipf and M. Welling, "Semi-supervised classification with graph convolutional networks," in *International Conference on Learning Representations (ICLR)*, 2017.

[18] P. Veličković, G. Cucurull, A. Casanova, A. Romero, P. Liò, and Y. Bengio, "Graph attention networks," in *International Conference on Learning Representations (ICLR)*, 2018.

[19] T. Pasquier, X. Han, T. Moyer, M. Bates, O. Hermant, D. Eyers, J. Bacon, and M. Seltzer, "Practical whole-system provenance capture," in *Proceedings of the ACM Symposium on Cloud Computing (SoCC)*, 2017, pp. 405–418.

[20] X. Han, T. Pasquier, A. Bates, J. Mickens, and M. Seltzer, "Unicorn: Runtime provenance-based detector for advanced persistent threats," in *Network and Distributed System Security Symposium (NDSS)*, 2020.

[21] W. U. Hassan, S. Guo, D. Li, M. Chen, K. Jee, Z. Li, and A. Bates, "Tactical provenance analysis for endpoint detection and response systems," in *IEEE Symposium on Security and Privacy (S&P)*, 2020, pp. 1172–1189.

[22] M. Tambe, *Security and Game Theory: Algorithms, Deployed Systems, Lessons Learned*. Cambridge University Press, 2011.

[23] E. Dahlhaus, D. S. Johnson, C. H. Papadimitriou, P. D. Seymour, and M. Yannakakis, "The complexity of multiterminal cuts," *SIAM Journal on Computing*, vol. 23, no. 4, pp. 864–894, 1994.

[24] H. Q. Ngo, M. Guo, and H. X. Nguyen, "Optimizing cyber response time on temporal active directory networks using decoys," in *Proceedings of the Genetic and Evolutionary Computation Conference*, ser. GECCO '24. New York, NY, USA: Association for Computing Machinery, 2024, pp. 1309–1317.